

1/53



File No.: EXP202213638

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

BACKGROUND

.....

2

FACTS

.....

2

FIRST:

.....

3

SECOND:

.....

3

THIRD:

.....

4

FOURTH:

.....

4

FIFTH:

.....

8

SIXTH:

.....

9

SEVENTH:

.....

9

EIGHTH:

.....

12

PROVEN FACTS

.....

12

FIRST:

.....

12

SECOND:

.....

13

THIRD:

.....

13

FOURTH:

.....

13

FIFTH:

.....

14

SIXTH:

.....

14

SEVENTH:

.....

14

EIGHTH:

.....

14

LEGAL GROUNDS

.....

15

I Competence

.....

15

II Termination of the procedure

.....

15

III Response to the allegations made against the initiation agreement

.....

16

Regarding the inaccuracies contained in the initiation agreement of the present
sanctioning procedure.

.....

16

Second allegation: On the impact on the principles of sanctioning law derived from the interpretation
made

Presented by the AEPD

.....

19

C/ Jorge Juan, 6

2/53

****Third Allegation: Regarding the alleged infringements attributed to Generali****

.....

26

****Fourth Allegation: Regarding the violation of the principle of proportionality****

...

32

****IV Unfulfilled obligation of Article 5.1 f)****

.....

33

****V Classification and qualification of the infringement of Article 5.1.f) of the GDPR****

.....

35

****VI Sanction for non-compliance with Article 5.1 f)****

.....

36

****VII Unfulfilled obligation of Article 32****

.....

38

****VIII Classification and qualification of the infringement of Article 32 of the GDPR****

.....

40

****IX Sanction for the infringement of Article 32 of the GDPR****

.....

41

****X Unfulfilled obligation of Article 25 of the GDPR****

.....

42

****XI Classification of the infringement of Article 25 GDPR****

.....

46

****XII Sanction for the infringement of Article 25 of the GDPR****

.....

47

****XIII Sanction for the infringement of Article 35 of the GDPR****

.....

48

****XIV Classification and qualification of the infringement of Article 35 of the GDPR****

.....

52

****XV Possible sanction for the infringement of Article 35 of the GDPR****

.....

53

****XVI Adoption of measures****

.....

54

****XVII Voluntary payment****

.....

54

****RESOLVES****

:

55

****FIRST:****

55

****SECOND:****

56

****THIRD:****

56

****FOURTH:****

56

****BACKGROUND****

****FIRST:****

(...) (hereinafter, the claiming parties) on November 18, 2022, filed a complaint with the Spanish Agency for Data Protection. The complaint is directed against GENERALI ESPAÑA, SOCIEDAD ANONIMA DE SEGUROS Y REASEGUROS with NIF A28007268 (hereinafter, GENERALI). The reasons on which the complaint is based are as follows:

In their writings, the claiming parties state that they received communication via email or by postal mail from GENERALI informing them of the occurrence of a cybersecurity incident in their systems.

According to the content

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/53

From said communication, the incident was due to “unauthorized access to the Information Systems, which has resulted in part of the information retained from when they were a client of GENERALI Spain, and in compliance with our legal and contractual obligations, being exposed.” Furthermore, it is indicated in the communication that such information “could include your data and that of the insured in your former policy relating to name, surname, address, landline and mobile phone, email, ID number, date and country of birth, marital status, and the IBAN code of your current account.”

From the documentation provided by the claiming parties in their various writings, the following stand out:

- Screenshots showing the communication received via email or postal mail from GENERALI through which information about the aforementioned security breach and its impact on the personal data of the claiming parties is provided.
- Screenshot of an email sent by one of the claimants to the responding party requesting the exercise of the right to erasure of their data.
- Screenshot of a letter sent by one of the claimants to the responding party requesting the non-renewal of the policy and the cancellation of all their personal data.
- Screenshot of an email from one of the claimants requesting information on why their data was being retained despite not being a client of the company since 2018, as well as a screenshot of the response from the responding party.

SECOND:

In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and the Guarantee of Digital Rights (hereinafter LOPDGDD), these claims were forwarded to the responding party for analysis and to inform this Agency within one month of the actions taken to

comply with the requirements set forth in the data protection regulations.

The transfers, which were carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter LPACAP), were formally notified as evidenced by the corresponding acknowledgments of receipt in the file. On 03/02/2023, this Agency received written responses to said transfers, the content of which is detailed below in the investigation report conducted by the General Subdirector of Data Inspection of this authority.

THIRD:

On 07/02/2023, in accordance with Article 65 of the LOPDGDD, the claims submitted by the claiming parties were admitted for processing.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

4/53

FOURTH:

The General Subdirector for Data Inspection proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the functions assigned to the control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions established in Title VII, Chapter I, Section Two, of the LOPDGDD, which concluded with a report containing the following conclusions:

Regarding the detection of the breach, the entry vector, and its impact, the report of the investigative actions concludes that:

- The attack was detected on October 5, 2022, after noticing performance issues and saturation in the application server. This problem was a consequence of the high number of requests that the attack was making in the customer maintenance application (SMC), which was used by insurance brokers to access the data of the clients they mediated. It has been established that the attackers compromised the access credentials of one of the brokers and used them to enter this application and execute an automated brute force attack against the customer inquiry form, making attempts with multiple random NIF numbers. On that same date, it was confirmed that the attack had been ongoing since September 19, 2022, without being detected by the systems of the defendant party.
- On October 6, 2022, the user through which the attack was being carried out was identified, and their credentials were changed, which contained the attack.
- According to the declaration of the responsible party, it has been established that, after the attack was detected, it was not possible to ascertain the impact on personal data since there were no logs or traces in the affected application, and therefore it could not be known how many of the requests made by the attackers were successful. They claim that at this date, only the potentially affected scenario was known, which corresponded to 37 individuals (clients or former clients) of that insurance broker. However, at a later date (November 11, 2022), it was learned that the potentially affected scenario was significantly larger due to a flaw in the software that allowed a broker to access personal data not only of their clients but also of any former client of GENERALI. On October 6, 2022, an initial assessment of the level of risk and severity of the breach was conducted (with the information available), concluding that it was not necessary to notify the incident to the AEPD or to the affected individuals.
- On November 11, 2022, it was confirmed that there had been a leak of personal data upon learning of the sale of a database of former clients of GENERALI through a Telegram group, with evidence obtained in the form of a sample of 24,315 records corroborating the following leaked personal data:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/53

- o Name and Surname.
- o ID number of the affected person.
- o ID number of the policyholder.
- o Phone1 and Phone2.
- o Date and country of birth.
- o Marital Status.
- o Full Address, Postal Code, City, Community.
- o IBAN.

It was on this same date that an error in the SMC software was detected, which had allowed the attackers to access not only the clients of the affected broker but also all former clients of the defendant party. On this date, a new assessment of the risk and severity of the incident was conducted, concluding the need to notify both the AEPD and the affected individuals.

Regarding the communication of the breach to the affected individuals, it has been established that GENERALI proceeded to inform the potentially affected former clients as follows:

- For the individuals included in the sample file obtained from the attackers, notification was made on November 15, 2022, via email or postal mail. A total of 24,352 individuals were informed.
- For former policyholders not included in the sample file, notification was made via email or postal mail between November 16 and 28, 2022 (1,092,543 potentially affected individuals).
- For former insured individuals of individual policies, there was a lack of contact data, and it was decided to include the information in the communication made to the former policyholder (399,153 potentially affected individuals).
- For former insured individuals of collective policies, it was decided to make a public communication on the website due to the lack of contact data; this communication was visible from November 30, 2022, to March 31, 2023 (166,621 potentially affected individuals).

It has been established that there were no risk analyses for the rights and freedoms of individuals in the processing activity affected by the breach, where potential threats that could cause harm or detriment to the individuals affected by these processes would have been identified and assessed, concluding with the appropriate technical and organizational measures to manage such risks. On the contrary, there was only a document that provided a general analysis or description of the processing with the purpose of determining the need to carry out an impact assessment (EIPD), concluding that the processing has a low impact level and that it is not necessary to carry out this EIPD.

C/ Jorge Juan, 6
 www.aepd.es
 28001 – Madrid
 sedeagpd.gob.es
 6/53

In relation to the technical and organizational preventive measures implemented prior to the breach, it is evidenced:

-
 (...)

Regarding the reactive measures implemented after the security breach, it has been evidenced:

-
 (...)

The deficiencies in the technical measures deployed to record and monitor user activity in the SMC application (...) resulted in the fact that, after the detection of the attack on October 5, 2022, it was not possible to ascertain its real impact and the personal data of former clients of the defendant that had been accessed, not being until November 11, 2022, that the impact of the leak was known through the sample obtained. After the breach, new reactive measures were introduced to ensure complete traces in this application and to control the transactions requested by users.

In relation to the retention periods of the personal data of former clients whose contractual relationship ended (end of insurance policies), it has been established:

-
 (...).

- That after the contractual relationship of a client ended (end of the policy), the retention period of the personal data for the purpose for which it was initially collected (insurance contract) was concluded. However, it has been established that the personal data continued to be processed for other purposes that justify it, referring to the following regulations:

- o Law 50/1980 on the development of the insurance contract (retention period 2 years).
- o Law 58/2003 on prescription in tax matters (retention period 4 years).
- o Commercial Code on the retention of business documents (retention period 6 years).
- o Law 20/2015 on fraudulent conduct related to insurance (retention period 5 years).
- o Law 10/2010 on the prevention of money laundering (retention period 5 years).

Despite changing the purpose for which the personal data continued to be processed, it has been established that both insurance agents (who are considered data processors) and insurance brokers (who are considered data controllers) continued to access the personal data of these former clients, although without the ability to edit them. As a reactive measure after the breach, the SMC application was modified so that mediators only had access to data of clients with active policies (policyholders, insured, and beneficiaries).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/53

FIFTH:

According to the report collected from the AXESOR tool, the entity GENERALI ESPAÑA, SOCIEDAD ANONIMA DE SEGUROS Y REASEGUROS is a company with (...) euros in the year 2022. In relation to the business volume according to the cited report, it reaches (...), expressed in "Volume of premiums for the year 2022," in the document "Report on the financial and solvency situation" of that year 2022, which has been incorporated into the file.

SIXTH:

On February 6, 2024, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against the defendant for the alleged infringement of articles 5.1.f), 25, 32, and 35 of the GDPR, classified in articles 83.4 and 83.5 of the GDPR.

SEVENTH:

On March 14, 2024, a document was entered into the registry of this authority presented by GENERALI, through which various allegations were made against the initiation agreement dated February 6, 2024. The content of this document highlights the following:

Regarding the inaccuracies contained in the initiation agreement of the present sanctioning procedure: The representation of Generali alleges several inaccuracies in the initiation agreement of the sanctioning procedure of the Spanish Agency for Data Protection.

Thus, first of all, Generali questions the assertion that the data of 800,000 former clients, including sensitive information such as IBAN, appeared in a Telegram forum and were accessible to the public. According to Generali, this assertion does not correspond with the documents of the administrative file. They argue that a user of a Telegram forum claimed to have the personal data but did not provide specific information or evidence of public access to this data. The cybersecurity company Lazarus detected the message and notified Generali, providing a limited sample of data to verify the veracity of the claim. It has not been proven that the data was available or publicly accessible in the Telegram forum, only that someone claimed to possess it.

Regarding the damages suffered by the affected parties, Generali argues that no real harm to those affected by the security breach has been evidenced. They state that only one claimant has expressed the intention to seek compensation for unproven moral damages, with no other claims for damages in the administrative file, which they consider means that the mentioned risks and damages are merely potential and not real.

They also oppose the assertion that the infringement is aggravated by the processing of sensitive data, including health data. Generali refutes this, stating that the affected system does not contain special

categories of data according to Article 9 of the GDPR. They point out that Generali has provided records of processing activities and communications to the affected parties, indicating that the compromised data was identifying, contact, and payment method data, but not health data.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

8/53

On the other hand, Generali argues that, contrary to what the AEPD has indicated, it is legal and necessary for insurance brokers to access information about former clients in order to fulfill various obligations. Furthermore, the Insurance Contract Law establishes limitation periods (two years for property insurance, five for personal insurance) during which claims may arise from contracts that have already ended. In this regard, brokers need access to the information to justify their remuneration and comply with tax and accounting obligations, while insurance agents, acting as data processors for insurers, need access to relevant information to fulfill their legal and contractual obligations.

Regarding the impact on the principles of sanctioning law derived from the interpretation made by the AEPD.

Generali claims that the initiation agreement incurs significant violations of the principles of administrative sanctioning law, particularly the principle of non bis in idem and the provisions of Article 29.5 of the Legal Regime of the Public Sector Law (LRJSP) concerning the concurrent commission of offenses.

Generali maintains that the AEPD is imposing multiple sanctions for facts that are, in essence, identical or intrinsically related, which compromises the principle of non bis in idem. This principle establishes that a person cannot be sanctioned twice for the same facts. In this case, the AEPD considers that Generali has committed four distinct violations of the GDPR: failing to adopt adequate security measures (Article 32.1), failing to comply with the principle of data protection by design (Article 25.1), failing to conduct a data protection impact assessment (DPIA) (Article 35), and violating the principle of confidentiality (Article 5.1 f).

Generali argues that these four accusations stem from the same fact: the security breach in the SMC application. It indicates that the AEPD, by imposing sanctions for each of these violations, would be duplicating sanctions for the same fact, as all the violations are inextricably linked. It points out that the AEPD is not imputing the lack of security measures in general but specifically in relation to the processing of data in the SMC. Generali argues that the AEPD follows a reverse reasoning: it takes the outcome of the security breach to deduce the lack of security measures, the absence of protection by design, and the lack of a DPIA. This approach, according to Generali, is incorrect and leads to the imposition of multiple sanctions for a single fact.

Regarding the alleged violations attributed to Generali.

In this allegation, Generali thoroughly addresses the specific violations that the Spanish Data Protection Agency attributes to it. The company follows an argumentative order that differs from the initiation agreement, starting with the principle of data protection by design.

First, Generali explains the scope of the principle of data protection by design, as outlined by the European Data Protection Board (EDPB) in its Guidelines 4/2019. These guidelines detail that technical and organizational measures can vary from advanced technical solutions to training.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/53

basic personnel. Generali argues that it has fulfilled its obligations under Article 25.1 of the GDPR, ensuring that it has conducted a thorough risk analysis and applied the necessary measures to mitigate such risks. It claims that the fact that Generali's system allowed mediators to access data of former clients is justified by the insurance distribution regulations that impose certain legal obligations. Regarding the alleged violation of Article 35 of the GDPR, Generali defends that a Data Protection

Impact Assessment (DPIA) was not necessary for the SMC application. Generali maintains that it has conducted a risk analysis that concluded that the data processing did not involve a high risk to the rights and freedoms of the data subjects. Furthermore, it argues that the AEPD seeks to introduce new criteria not contemplated in the GDPR, which exceeds its competence.

Concerning the insufficiency of security measures (Article 32 of the GDPR), Generali reaffirms that it has implemented adequate measures to protect personal data and that the security breach was the result of factors beyond its control, such as the compromise of a mediator's credentials. Generali argues that it has diligently adopted reactive measures and that the fact that these measures were implemented quickly demonstrates its commitment to data security, not an admission of prior insufficiency.

Finally, regarding the alleged violation of the principle of confidentiality (Article 5.1.f of the GDPR), Generali asserts that the AEPD is sanctioning the existence of the security breach as a result rather than a lack of means, which contradicts the jurisprudence of the Supreme Court that establishes that the obligation of security is an obligation of means, not of results. Generali argues that the notification of the breach to the affected parties should not be interpreted as an admission of insufficiency of the security measures.

In conclusion, Generali defends that each of the allegations made by the AEPD is based on incorrect assumptions or misinterpretations of the applicable regulations, and that it has diligently and adequately fulfilled its obligations under the GDPR.

Regarding the violation of the principle of proportionality:

Generali argues that, in the event it is determined that it has infringed data protection regulations, the principle of proportionality should be considered when determining the sanction. To this end, Generali cites the jurisprudence of the Supreme Court, which establishes that the sanction must be proportional to the infringement committed, taking into account all concurrent circumstances.

Generali criticizes the AEPD for not having conducted a meticulous evaluation of these circumstances, noting that relevant mitigating factors have not been considered, such as the rapidly adopted reactive measures, the lack of prior sanctions, the voluntary notification of the incident to the AEPD, and adherence to codes of conduct.

Generali also refutes the aggravating circumstances applied by the AEPD, arguing that these are based on inaccurate facts or on an objective assessment without specific evidence of negligence.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/53

In conclusion, Generali argues that, if a violation were to be determined, the penalty should be significantly lower due to the presence of various mitigating factors and the lack of justification for the aggravating factors invoked by the AEPD.

EIGHTH:

On April 12, 2024, a document from Generali was entered into the registry of the present authority, through which it states that it has proceeded with the voluntary payment without acknowledgment of responsibility, in the following terms:

“XI: That in exercise of the power granted by the aforementioned article 85.2 of the LPACAP, Generali has proceeded to pay 80% of the proposed penalty, that is, the amount mentioned in the previous exposition. To this end, DOCUMENT NUMBER 1 is submitted as proof of payment made by Generali.

XII: That, as a consequence of the aforementioned payment, my represented party waives the exercise before that AEPD of any action or administrative appeal against the penalty that, eventually and against what is supported by Generali, may be imposed, as prescribed by article 85.3 of the LPACAP, and therefore states that it will not file an optional appeal for reconsideration against the resolution that may ultimately be issued by that AEPD.

XIII: That, nevertheless, and as indicated in the previous expositions, the aforementioned payment is made in exercise of the power established in article 85.3 and does not imply in any case agreement with the content of the Initiation Agreement nor with that of the resolution that may be issued, if it

corresponds, in whole or in part, with the content of said Agreement. Likewise, the making of the aforementioned payment must not be interpreted in any case as an acknowledgment by Generali of responsibility for the commission of the alleged violations that may be attributed to it in the aforementioned resolution. To this end, Generali expressly reiterates its intention to challenge the aforementioned resolution, in case it does not imply the filing of the present file, before the contentious-administrative jurisdiction.”

In view of all that has been acted upon, the Spanish Agency for Data Protection considers the following proven facts in the present procedure,

PROVEN FACTS

FIRST:

It is established that on October 5, 2022, the responding party detected a brute force attack against the customer inquiry form using the credentials of a broker, making attempts with multiple random NIF numbers, and it was decided not to notify the incident.

This fact has been confirmed by the responding party itself during the course of the investigation proceedings: “On 10/5/22 a brute force attack was detected using broker credentials. Applying the ENISA and AEPD rules, it was decided not to notify the incident (which could affect 37 interested parties). On that date, access to that broker was blocked and their credentials were modified, ceasing the attack.”

SECOND:

On November 11, 2022, the responding party became aware of the leakage of personal data due to the attack following a communication from the cybersecurity company (...) that affected the following personal data:

- Name and Surname.
- ID number of the affected person.
- ID number of the policyholder.
- Phone1 and Phone2.
- Date and country of birth.
- Marital Status.
- Complete Address, Postal Code, City, Community.
- IBAN.

THIRD:

It has been established that GENERALI proceeded to inform potentially affected former clients of the breach, pursuant to article 33 of the GDPR, in the following manner:

- For the individuals included in the sample file obtained from the attackers, 24,352 people were informed on November 15, 2022, via email or postal mail.
- For former policyholders not included in the sample file, communication was made via email or postal mail between November 16 and 28, 2022, to a total of 1,092,543 potentially affected individuals.
- For former insured individuals of individual policies, there was a lack of contact data, and it was decided to include the information in the communication made to the former policyholder (399,153 potentially affected individuals).
- For former insured individuals of collective policies, it was decided to make a public communication on the WEB due to the lack of contact data; this communication was visible from November 30, 2022, to March 31, 2023 (166,621 potentially affected individuals).

FOURTH:

It has been established that at the time of the attack, the responding party did not have a risk analysis for the rights and freedoms of individuals in the processing activity in order to identify and evaluate the possible threats that could cause harm or detriment to the individuals affected by these treatments.

This fact is evidenced in the investigation proceedings through which the aforementioned risk analysis was repeatedly requested, receiving as

12/53

response that "the processing is prior to the entry into force of the GDPR, (...), therefore it has not been subject to an analysis subsequent to the one already provided, without prejudice to the measures adopted as a consequence of the detected security breach."

FIFTH:

It is established that, at the time of the attack, the responding party did not have an approved Data Protection Impact Assessment (DPIA) for the processing of its activity.

This is evident from the very statement of the responding party, as well as from the document provided by it through which a general analysis or description of the processing was carried out with the purpose of determining the need to carry out a DPIA, concluding that the processing had a low impact level and that it was not necessary to carry out this DPIA.

SIXTH:

It is established that, at the time of the attack, the second factor of authentication was not implemented in the responding party's application for insurance brokers.

This fact has been stated by the responding party and confirmed through the accreditation of the reactive measures implemented after the occurrence of the breach: "(...)"

SEVENTH:

It is established that, until the adoption of the reactive measures by the responding party after the breach occurred, and due to a technical failure in the update of the Customer Maintenance System (CMS) software, insurance brokers could access both data of their clients and former clients who no longer had a contractual link, as well as former insured parties under policies.

This has been corroborated by the responding party and confirmed in the communication of the reactive measures: "(...)."

EIGHTH:

It has been established that there were no logs of transactions to ensure traceability in the system, which prevented immediate knowledge of the actual impact of the breach and the affected personal data. This is evident from the very statement of the responding party during the course of the investigation proceedings: "There are no application logs that help define how many successful hits the massive attack had."

NINTH:

From the investigative actions carried out, it is established that GENERALI had, at the time prior to the breach, the following technical and organizational preventive measures:

-

(...)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

13/53

TENTH:

It is established that GENERALI adopted the reactive measures implemented after the security breach:

-

(...)

LEGAL GROUNDS

I Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter, LOPDGDD), the Director of the Spanish Data Protection Agency is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states that: "The procedures processed by the Spanish Data Protection Agency shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II Termination of the procedure

Article 85, second paragraph, of the LPCAP establishes that "When the sanction is solely of a

pecuniary nature or when it is possible to impose a pecuniary sanction and another of a non-pecuniary nature but the impropriety of the second has been justified, voluntary payment by the alleged responsible party, at any time prior to the resolution, will imply the termination of the procedure, except in relation to the restoration of the altered situation or the determination of compensation for the damages caused by the commission of the infringement.”

Such voluntary payment implies, as indicated in the third paragraph of the same article, the corresponding reduction on the amount of the sanction: “In both cases, when the sanction is solely of a pecuniary nature, the competent authority to resolve the procedure shall apply reductions of at least 20% on the amount of the proposed sanction, which shall be cumulative. The aforementioned reductions must be determined in the notification of initiation of the procedure and their effectiveness shall be conditioned on the withdrawal or renunciation of any action or administrative appeal against the sanction.”

In these terms, taking into account the voluntary payment made and communicated by Generali before the resolution proposal was issued by this authority, the termination of the present sanctioning procedure is carried out in the terms indicated in the dispositive part of this resolution.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

14/53

However, it is appropriate to highlight that, prior to the aforementioned voluntary payment, Generali submitted a written statement of allegations against the initiation agreement, proceeding to a detailed analysis of the indicated infractions and legally rebutting each one of them. This fact obliges the present authority to rule on such allegations in accordance with the provisions of Article 88 of the LPACAP, which expressly states that:

“The resolution that concludes the procedure will decide all the issues raised by the interested parties and any other matters arising from it.”

In light of the above, in compliance with this legal mandate, through this resolution, we proceed to respond to the allegations made by Generali against the initiation agreement, as well as to declare the termination of the procedure for early payment in the terms established in Articles 85.2 and 88 of the LPACAP.

III Response to the allegations made against the initiation agreement

Regarding the inaccuracies contained in the initiation agreement of the present sanctioning procedure.

Firstly, Generali claims that the data of former clients was not accessible to the public through a Telegram forum. However, from the investigative actions carried out, it follows that on November 11, 2022, the sale of a database of former clients of Generali was confirmed in a Telegram group, which corroborates the public exposure of this data. Thus, in the aforementioned conclusions of the acting inspector, it is expressly stated that GENERALI was aware of the personal data leak:

“On November 11, 2022, it was confirmed that personal data had been leaked upon learning of the sale of a database of former clients of GENERALI through a Telegram group, with evidence obtained in the form of a sample of 24,315 records that corroborated the following leaked personal data:

- o Name and Surname.
- o ID number of the affected person.
- o ID number of the policyholder.
- o Phone1 and Phone2.
- o Date and country of birth.
- o Marital Status
- o Complete Address, Postal Code, City, Community.
- o IBAN”

This evidence contradicts Generali's assertion that there was no public access to the compromised data.

On the other hand, this fact is confirmed by Generali during the course of the investigative actions, in

response to the prior request of the present authority regarding the possible websites where the information was leaked, indicating in this regard that the provider Lazarus informed them that the data had been located through a Telegram group.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
15/53

Notwithstanding the above, it is worth highlighting that regardless of whether the data was or was not accessible in a forum, the mere fact that it has been exposed to an unauthorized third party already constitutes a violation of the principle of confidentiality as established by Article 5.1 f) of the GDPR. In relation to the harm suffered by the affected parties, Generali argues that no actual damage has been proven. In this regard, it is essential to emphasize that, considering the content of the GDPR, it is not necessary for "real" damage to occur for the infringements proposed in the initiation agreement to be committed. In the GDPR, the violation of the principle of confidentiality provided for in Article 5.1.f), the data protection by design referred to in Article 25, the adoption of appropriate security measures according to the risk as stipulated in Article 32, or the obligation of the Impact Assessment required by Article 35 of the GDPR, none of these require the occurrence of "real" damage for these provisions to be understood as infringed.

In this regard, it is important to determine what is understood by damage or harm in the context of the GDPR and the rights of the data subjects. Generali argues that no "real" damage has been proven, but does not specify whether it refers to tangible or physical damage, economic harm, or if it is limiting the damage to a material and concrete manifestation.

The GDPR clearly establishes in its Article 5.1.f) that the loss of confidentiality of personal data constitutes an infringement, as the exposed data is made available to unauthorized third parties. This fact undoubtedly affects the data subject, as they lose their ability to control their personal data. Furthermore, Recital 85 of the GDPR indicates that the loss of confidentiality and integrity poses a risk that may lead to physical, material, or immaterial damages, which demonstrates that tangible or economic damage is not necessary for the GDPR to consider that the rights of the data subject have been violated:

"The risks to the rights and freedoms of natural persons, of varying severity and probability, may arise from the processing of data that could cause physical, material, or immaterial harm, particularly in cases where the processing may lead to discrimination, identity theft or fraud, financial losses, damage to reputation, loss of confidentiality of data subject to professional secrecy, unauthorized reversal of pseudonymization, or any other significant economic or social harm; in cases where data subjects are deprived of their rights and freedoms or prevented from exercising control over their personal data; ..."

In short, the infringement of the GDPR does not require "real" or tangible damage to be considered as such. The loss of control over the data and the materialization of the risk already constitutes a violation of the rights of the data subject, according to the aforementioned.

The protection of personal data constitutes a fundamental right that must be guaranteed, and the violation of the obligations indicated by the GDPR occurs regardless of whether it materializes in tangible damage for the data subjects.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
16/53

affected individuals. It should be noted that the regulation focuses on the prevention of risks and the protection of the rights and freedoms of individuals, which implies that on various occasions, the mere possibility that the data could be used improperly is sufficient to consider that one of the obligations established by the regulation has been violated.

In light of the above, Generali's argument regarding the alleged absence of real harm is not sufficient to justify the breach of its obligations. Data protection regulations are based on identifying the risks to

the rights and freedoms of individuals arising from the processing of personal data, as well as on preventing and mitigating the realization of the risks associated with the processing of personal data. The lack of evidence of specific harm for each affected individual does not exempt Generali from its responsibility to comply with the obligations established in the GDPR.

Regarding data belonging to special categories, Generali claims that the affected system did not contain special categories of data as provided in the GDPR. However, it is important to note that, as the responding party is aware, Generali manages health insurance, which necessarily involves the processing of data related to health, which falls under Article 9 of the GDPR as special categories of personal data.

The fact that the personal data breach did not specifically affect this type of data on this occasion does not exempt Generali from complying with the obligations established in the GDPR, considering the nature of these special categories of data involved in its processing. This implies that data protection impact assessments (DPIAs), security measures, and the design of systems by default must take into account the special circumstances, as well as the inherent risks associated with the management of the aforementioned data.

In light of the above, Generali's argument (...) is not sufficient to undermine the broader obligations they have under the GDPR. While the existence of such data is not the primary basis for the breach of obligations by Generali, it can be taken into account for the purpose of assessing the severity of the infringement.

Finally, Generali defends the legal necessity for insurance intermediaries to access information about former clients to comply with various contractual and regulatory obligations. In this regard, it is crucial to differentiate between the obligation to retain data of former clients for legal obligations and the access to that data by intermediaries regarding individuals who no longer hold the status of client.

In this context, Generali has the obligation to retain the personal data of former clients to comply with several regulatory provisions, such as those related to tax obligations, money laundering, and contractual claims that may arise even after the termination of the contractual relationship. However, this obligation of retention does not justify unrestricted access to this data by insurance intermediaries. Allowing insurance intermediaries unrestricted access to information about former clients, in addition to

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

17/53

Violating the principle of confidentiality severely compromises the protection and security of personal data.

Although Generali has the obligation to retain this data for legal reasons, such obligation does not exempt it from the responsibility to ensure that access is restricted exclusively to authorized personnel, in relation to job functions and under justified circumstances.

Retaining personal data of former clients does not imply that any employee or insurance broker has the right to freely access this information, as this would constitute an improper and disproportionate use that is not justified by the nature of the retention obligation.

In fact, such assertions are also shared by the responding party. The investigation actions reveal that, following the breach, Generali implemented measures to restrict brokers' access only to data of clients with active policies, indicating that previous actions were insufficient to ensure adequate protection of personal data, as stated in the seventh proven fact.

Second Allegation: Regarding the impact on the principles of sanctioning law derived from the interpretation made by the AEPD

Generali argues that the initiation agreement incurs violations of the principles of sanctioning administrative law, particularly the principle of non bis in idem and the provisions of Article 29.5 of the Law on the Legal Regime of the Public Sector (LRJSP) in relation to the medial concurrence of infractions. In this regard, it is appropriate first to make a brief reference to the application of the aforementioned principle in the European context, considering the nature of the GDPR.

Article 50 of the Charter of Fundamental Rights of the European Union (CFR) establishes the principle

of non bis in idem, which prohibits double prosecution and double penal sanction within the European Union. Unlike Article 4 of Protocol 7 of the European Convention on Human Rights (ECHR), which applies only at the national level, Article 50 of the CFR has a transnational scope, protecting individuals from being judged or sanctioned twice for the same infraction in any Member State of the European Union, provided that Union law is applied.

Under the title "Right not to be tried or punished twice for the same offense," Article 50 states:

"No one shall be tried or punished criminally for an offense for which they have already been acquitted or convicted in the Union by a final criminal judgment in accordance with the law."

The Charter, considered a primary source of Union law according to Article 6 of the Treaty on European Union, regards all Member States as a single legal space concerning the rule of non bis in idem, provided that they apply Union law.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

18/53

Furthermore, the Court of Justice of the European Union has applied the Engel criteria, originating from the case law of the European Court of Human Rights (ECHR), to interpret Article 50 of the Charter of Fundamental Rights of the European Union (CFR). These criteria determine whether a sanction is of a criminal nature based on the legal classification of the offense, the nature of the offense and the sanction, as well as the severity of the sanction. Thus, the prohibition of double jeopardy can extend not only to criminal proceedings but also to administrative procedures with sanctions of a criminal nature or character.

The Charter, in its Article 52.3, provides that the rights corresponding to those guaranteed by the ECHR shall have the same meaning and scope. The CJEU has emphasized that Article 50 of the CFR must be interpreted uniformly and autonomously, without depending on the ratification or reservations to the ECHR by the Member States.

Regarding the jurisprudential requirements established by the CJEU for the aforementioned principle recognized in Article 50, the European Court has stated in various judgments (CJEU Judgment of July 18, 2007, *Lucchini Siderurgica*, C-119/05, EU:C:2007:434; CJEU Judgment of November 16, 2010, *Mantello*, C-261/09, EU:C:2010:683; Judgment of March 20, 2018, *Menci*, C-524/15, EU:C:2018:197) the necessity of the concurrence of three criteria for the cited principle to apply:

- ****Identity of the offender:**** The same person or entity must be subject to the proceedings or sanctions. "The same individual must be subject to both proceedings or sanctions. This ensures that different persons are not prosecuted or sanctioned for the same facts."
- ****Identity of the facts:**** The facts must be the same ("idem factum"), that is, a set of specific circumstances inextricably linked to each other. "The material facts must be the same. This means that they must be a set of specific circumstances arising from events that are, in essence, the same in that they involve the same author and are inextricably linked in time and space."
- ****Identity of the protected norm:**** "The offense must affect the same protected legal interest."

However, this principle has been nuanced and modulated by the jurisprudential doctrine of the CJEU, among which we can highlight the following resolutions regarding its scope:

- ****Judgment of March 22, 2022, *Nordzucker*, C-151/20, EU:C:2022:203:**** The CJEU reaffirms in this judgment the importance of the identity of the material facts ("idem factum") for applying the principle of non bis in idem. The court allows the accumulation of sanctioning procedures when the sanctions arise from different legal offenses pursuing different general interests. In the case of *Nordzucker*, although the sanctioned behaviors were related, the legal offenses were distinct, thus justifying the accumulation of sanctions.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

19/53

-
Judgment of March 20, 2018, Menci, C-524/15, EU:C:2018:197: The Menci judgment addresses the issue of the duplication of criminal sanctions in the context of tax evasion. The CJEU establishes that the principle of non bis in idem prohibits the duplication of criminal sanctions for the same facts, but allows exceptions when the sanctions pursue complementary objectives of general interest. Furthermore, the court emphasizes the need for proportionality and coordination in the accumulation of sanctions. In this case, the accumulation of tax and criminal sanctions was deemed justified due to the complementary objectives at stake.

-
Judgment of February 26, 2013, Åkerberg Fransson, C-617/10, EU:C:2013:105: In the Åkerberg Fransson judgment, the CJEU analyzes the application of the principle of non bis in idem in the context of tax and criminal sanctions for the same offense of failing to declare taxes. The court concludes that the accumulation of administrative and criminal sanctions for the same facts is not contrary to the principle of non bis in idem if the principles of proportionality and coordination are respected. In this case, both the tax fine and the criminal proceedings were considered of a criminal nature, but the accumulation of sanctions was allowed under certain conditions.

In summary, the principle of non bis in idem according to Article 50 of the Charter of Fundamental Rights of the European Union (CDFUE) and its interpretation by the CJEU protects individuals from being sanctioned twice for the same offense in any Member State of the European Union, ensuring a unique and coherent legal space in the application of Union Law. This legal and jurisprudential framework is useful for analyzing Generali's allegation regarding the supposed violation of this principle by the AEPD.

In the case at hand, regarding the violations indicated in the initiation agreement, while there is indeed identity of the offender, the same does not occur with the identity of the facts and the protected legal interest. In this sense, taking into account the administrative and specific nature of the norm, the protected legal interest cannot be understood generally as the protection of personal data, but rather as the principle or principles or essential content on which the specific obligation or infringement is based and motivates the sanction. Considering the aforementioned criteria, it follows that each of the violations indicated in the agreement are independent and differentiated, in the terms that are subsequently outlined:

Violation of the principle of confidentiality (Article 5.1.f of the GDPR)

The obligation of confidentiality that Article 5.1.f) of the GDPR imposes on the data controller is an obligation of result, such that for the provision to be deemed infringed, the confidentiality of the data must be breached. Thus, we would be faced with an infringement of result, unlike what is provided in Article 32 of the GDPR, which, as will be seen later, imposes an obligation of means.

In the case at hand, the facts that constitute the violation of this principle and, consequently, the infringement, manifest in the personal data breach that occurred. As a result of the attack, there was unauthorized exposure of personal data, including names, addresses, phone numbers, ID numbers, and banking data such as the IBAN.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

20/53

Certainly, the principle of liability provided for in Article 28.1 of Law 40/2015, of October 1, on the Legal Regime of the Public Sector, states that: "Only individuals and legal entities, as well as, when a law recognizes their capacity to act, the groups of affected parties, unions, and entities without legal personality and independent or autonomous assets, may be sanctioned for acts constituting administrative infractions, who are found liable for the same on the grounds of intent or negligence."

However, according to the ruling in STS 7887/2011 of November 24, 2011, Rec. 258/2009, "(...) since its ruling 76/1990, of April 26, the Constitutional Court has declared that objective or faultless liability is not applicable in the administrative sanctioning sphere, a doctrine that is reaffirmed in ruling 164/2005, of June 20, 2005, whereby the possibility of imposing sanctions solely based on the outcome, without

demonstrating a minimum level of culpability even in terms of mere negligence, is excluded. However, the manner of attributing liability to legal entities does not correspond to the forms of intentional or negligent culpability that are attributable to human conduct."

Thus, in the case of infractions committed by legal entities, although the element of culpability must be present (see the ruling of this Chamber of the Supreme Court of November 20, 2011, cassation appeal in the interest of the law 48/2007), it is necessarily applied differently than it is with individuals.

According to STC 246/1991 "(...) this distinct construction of the attribution of authorship of the infraction to the legal entity arises from the very nature of the legal fiction to which these subjects respond. They lack the volitional element in the strict sense, but not the capacity to infringe the norms to which they are subject. The capacity to infringe and, therefore, direct reproachability derives from the legal interest protected by the norm that is infringed and the necessity for that protection to be genuinely effective and from the risk that, consequently, the legal entity subject to compliance with that norm must assume."

To the above, it should be added, following the ruling of January 23, 1998, partially transcribed in STS 6262/2009, of October 9, 2009, Rec 5285/2005, and STS 6336/2009, of October 23, 2009, Rec 1067/2006, that "although the culpability of the conduct must also be subject to proof, it should be considered in terms of the assumption of the corresponding burden, that ordinarily the volitional and cognitive elements necessary to appreciate it form part of the proven typical conduct, and that their exclusion requires demonstrating the absence of such elements, or in its normative aspect, that due diligence was exercised by the one claiming its non-existence; in short, the mere invocation of the absence of fault is not sufficient for exculpation against a typically unlawful behavior."

In light of these matters, none of the circumstances present in the case allow for the exclusion of this subjective element of the infraction.

Regarding the legal interest protected by Article 5.1.f of the GDPR, it is the confidentiality of personal data. This principle establishes that personal data must be processed in a manner that ensures adequate security, including protection against unauthorized or unlawful processing.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

21/53

Confidentiality implies that personal data is not accessible or disclosed to unauthorized persons and that it is kept protected at all times during its processing.

****Data Protection by Design and by Default (Article 25.1 of the GDPR)****

Article 25.1 of the GDPR establishes the obligation for data controllers to integrate appropriate organizational and technical measures of all kinds, from the design stage and by default. This provision ensures that the protection of personal data is considered and applied from the earliest stages of development and throughout the entire data processing lifecycle. Protection by design involves identifying, evaluating, and analyzing risks to the rights and freedoms of data subjects, adopting all types of appropriate technical and organizational measures to mitigate such risks related to the intended processing before it begins, in order to effectively apply the principles of data protection, such as data minimization, and to integrate the necessary safeguards in the processing, in order to comply with the requirements of the GDPR and protect the rights of data subjects. On the other hand, data protection by default refers to applying appropriate technical and organizational measures of all kinds to ensure that, by default, only personal data that is necessary for each specific purpose of the processing is subject to processing. Such measures will ensure in particular that, by default, personal data is not accessible, without the intervention of the individual, to an indeterminate number of natural persons, limiting the amount of personal data collected and processed to what is strictly necessary, ensuring that personal data is accessible only to authorized persons and for authorized purposes, and establishing default settings that prioritize security.

In the case of Generali, the infringement is evidenced in (...). The lack of these measures allowed unauthorized access to personal data of former clients, and the system configuration did not guarantee

the principle of data minimization in the processing of personal data nor restricted access only to necessary data limited to specific purposes.

It is crucial to understand that in this case, the act constituting the infringement is not the personal data breach itself, but the deficiencies in the design and configuration of its systems and processes. In this case, the breach was the event that allowed the deficiency of the implemented system to be discovered and, therefore, the non-compliance with the principle, but not the cause of the non-compliance. Article 25.1 of the GDPR obliges data controllers to integrate data protection measures from the design phase of any system that processes personal data and to ensure that, by default, only the data necessary for each specific purpose is processed. This implies that, regardless of whether a breach occurs or not, the system must be designed and operated in such a way as to minimize the possibility of undue exposure of personal data. Therefore, the act subject to sanction under Article 25.1 of the GDPR (...), and not the personal data breach that subsequently occurred. It constitutes, therefore, an infringement in itself and independently of the personal data breach.

The legal interest protected by Article 25.1 of the GDPR is the protection of personal data from its conception and throughout its lifecycle. This article ensures

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

22/53

that proactive measures be adopted to integrate data protection safeguards into the design of systems and processes, and that such systems be configured in a way that prioritizes protection by default. The essential content focuses on ensuring that data protection is not an afterthought or a secondary consideration, but rather an integral part of the design and operation of all systems and processes that handle personal data.

Insufficiency of security measures appropriate to the risk (Article 32 of the GDPR)

Article 32 of the GDPR is a key provision that establishes the obligation for data controllers and processors to implement appropriate technical and organizational security measures to ensure the security of personal data. This article highlights the importance of protecting data against various threats, such as destruction, loss, alteration, unauthorized communication, or access. Through these measures, the GDPR seeks to ensure that personal data is kept secure and protected at all times.

Article 32 does not specify exact measures that must be adopted, but rather requires that these measures be appropriate to ensure a level of security commensurate with the risk posed by the processing of personal data. This implies that data controllers must continuously assess risks and adapt their security measures accordingly, an obligation that does not guarantee that personal data breaches will not occur, but rather an obligation of means to ensure an adequate level of security relative to the specific processing risk.

The security of personal data, as a legal asset protected by Article 32, encompasses both technical aspects (such as the use of encryption and pseudonymization) and organizational aspects (such as access policies and training procedures). This comprehensive approach ensures that all aspects of data security are addressed, from technical infrastructure to staff conduct.

Article 32 of the GDPR, unlike Article 5.1(f), imposes an obligation of means, meaning that data controllers must demonstrate that they have taken all appropriate technical and organizational security measures to ensure a level of security appropriate to the risk, rather than guaranteeing a specific outcome. This translates into the need for a proactive and continuous approach to data security management, adjusting measures as risks and threats evolve.

In the case at hand, the lack of adoption of appropriate technical and organizational measures was manifested through the personal data breach; however, it was not this breach that led to the violation of the obligation set forth in Article 32. On the contrary, it was the subsequent verification of the measures adopted that highlighted the failure to comply with this obligation independently of the personal data breach (there were inadequate measures even if the breach had not occurred) and, consequently, the infringement provided for in the GDPR.

The purpose of Article 32 of the GDPR is to ensure an adequate level of security relative to the risk of processing personal data, through the application of appropriate technical and organizational security measures, specifically for security, as

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

23/53

Here the Law does make a distinction. And all of this is independent of whether there is a loss of confidentiality and/or integrity, as the absence of such a level of security appropriate to the risk has significance in itself to determine the violation of the provision.

Furthermore, we refer to the response regarding the breach of this obligation as stated in the third allegation concerning the lack of technical and organizational measures related to the personal data breach.

Lack of Data Protection Impact Assessment (Article 35 of the GDPR)

Article 35 of the GDPR establishes the obligation to carry out a Data Protection Impact Assessment (DPIA) when a type of processing may pose a high risk to the rights and freedoms of natural persons. As established by the Guidelines of the Article 29 Working Party on the data protection impact assessment (DPIA) and to determine whether the processing "likely results in a high risk" for the purposes of Regulation (EU) 2016/679 adopted on April 4, 2017:

"A DPIA is a process designed to describe the processing, assess its necessity and proportionality, and help manage the risks to the rights and freedoms of natural persons arising from the processing of personal data by evaluating them and determining the measures to address them. DPIAs are important accountability tools, as they help controllers not only to comply with the requirements of the GDPR but also to demonstrate that appropriate measures have been taken to ensure compliance with the Regulation."

In the present case, the fact that motivates the non-compliance and the infringement consists precisely in the failure to carry out a DPIA, despite the inherent risks of their data processing requiring it. Consequently, neither the breach that occurred nor the lack of adoption of measures have any relevance in the non-compliance with the obligation; only the absence of such an assessment when one is obliged to carry it out is the fact that determines the non-compliance with Article 35 of the GDPR.

Generali did not carry out a DPIA despite the fact that its data processing operations presented high risks to the rights and freedoms of the data subjects. As indicated in the initiation agreement, Generali operates in an environment where large volumes of personal data are processed, some of which are of a sensitive nature.

The legal interest protected by Article 35 of the GDPR is the assessment and mitigation of risks to the rights and freedoms of natural persons associated with the processing of personal data. This article requires that controllers carry out a DPIA when the processing operations may pose a high risk to the rights and freedoms of the data subjects. The purpose is to ensure that potential risks are identified and mitigated before harm materializes, as well as to establish containment measures if the risk has materialized, thereby effectively protecting personal data.

In conclusion, each of the infringements indicated in the initiation agreement represents a differentiated and autonomous infringement, without any concurrence between them.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

24/53

including the intermediary. The breach of Article 32 of the GDPR focuses on the failure to adopt appropriate technical and organizational security measures to ensure a level of security appropriate to

the risk, while the lack of data protection by design under Article 25.1 of the GDPR centers on the absence of the integration of safeguards and measures of all kinds from the conception of systems in order to comply with the principles of the GDPR and all its requirements, protecting the rights of the data subjects. The lack of a data protection impact assessment under Article 35 of the GDPR constitutes the absence of a mandatory and specific risk analysis when processing entails a high risk and reflects the omission in identifying and mitigating risks proactively, while the violation of the confidentiality principle under Article 5.1(f) of the GDPR, established to ensure the integrity and confidentiality of personal data, underscores the resulting personal data breach due to the unauthorized exposure of personal data. These infringements protect distinct legal goods and stem from different facts in certain critical aspects of personal data management, constituting different violations and justifying independent sanctions.

On the other hand, it is worth referring to Generali's argument that the sanctions should be considered under the principle of medial concurrence according to Article 29.5 of the LRJSP, which establishes that when the commission of one infringement necessarily leads to the commission of another, only the sanction corresponding to the most serious infringement shall be imposed. However, in the context of the GDPR, Article 83.3 provides a specific framework for addressing concurrent infringements, ensuring that all relevant violations are attributed and considered, but without resulting in excessive or unfair penalties.

Furthermore, the guidelines of the European Data Protection Board (EDPB) on the calculation of fines also recognize the possibility of concurrent infringements and establish that each infringement must be considered separately in its own context, although the total sanction is adjusted to avoid unfair duplications.

Nevertheless, in the present case, the application of Article 83 of the GDPR does not concur since, as indicated, we are faced with breaches based on perfectly differentiated behaviors that autonomously motivate the commission of different infringements provided for in the GDPR. Each of the infringements attributed to Generali corresponds to specific facts and distinct legal grounds, without the necessity for one of them to concur for the others to occur.

Third Allegation: Regarding the alleged infringements attributed to Generali

In this allegation, Generali thoroughly addresses the specific infringements indicated in the initiation agreement. Below, the arguments regarding each of them are analyzed and rebutted.

Principle of data protection by design (Article 25.1 of the GDPR).

Generali claims that it has complied with the principle of data protection by design by conducting a thorough analysis of the risks associated with data processing and implementing the necessary measures to mitigate them. However, Generali confirmed that the implementation of the Customer Maintenance Service allowed intermediaries to access data of former clients. This unauthorized access to data

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

25/53

Personal data of former clients demonstrates that Generali did not adequately implement the necessary technical and organizational measures from the design of its systems to limit access to the data solely for the specific purposes for which they were collected.

Furthermore, Generali argues that this access is justified by the regulatory framework governing the distribution of private insurance, which requires distributors to have access to information about clients whose policies have been resolved. Moreover, this argument contradicts its own actions—since Generali has indicated that it has adopted the measure consisting of (...)—however, this argument does not exempt Generali from its obligation to implement measures from the design stage. Data protection regulations and sector-specific regulations must coexist, and Generali has the responsibility to ensure that both are complied with, by implementing measures that limit access to personal data to authorized individuals based on their functions and to what is strictly necessary in relation to the purpose for which they are processed. Data protection by design requires, among other things, that

before processing takes place, the roles and responsibilities of the individuals who will handle personal data within the data controller are evaluated to prevent access by an indeterminate number of individuals.

Generali also argues that the application was put into operation before the full implementation of the GDPR, and therefore, it is unreasonable to expect that its initial design took into account the obligations imposed by the regulation. In this regard, it is important to note that the entry into force of the GDPR requires data controllers to review and update their systems and processes to comply with the new legal obligations. The implementation of appropriate measures from the design stage is not limited to the initial creation of a system, but is a continuous process that must adapt to changes in regulations and in the (changing) risks to the rights and freedoms of individuals regarding the processing of personal data. On the contrary, the lack of adequate updating of the SMC application to comply with the GDPR demonstrates a lack of diligence on the part of Generali in this aspect. It is also worth noting that the fact that the application was put into operation before the full application of the GDPR, as they claim, does not exempt them from compliance with the obligation once the regulation had full effect following its full applicability in May 2018.

Finally, Generali claims that it has implemented reactive measures following the security incident, a fact that actually reinforces the AEPD's argument that not all implications regarding data protection were taken into account in relation to data protection by design and by default, specifically referring to the measure consisting of the lack of profile segmentation that was adopted after the personal data breach.

In conclusion, Generali's argumentation does not adequately justify the lack of data protection measures by design and by default. The actions and omissions of Generali demonstrate that not all necessary measures were taken to ensure that personal data was protected from the outset, and that the

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
26/53

Access will be strictly limited to the appropriate individuals and necessary purposes, as required by the GDPR.

Violation of Article 35 of the GDPR in relation to the Data Protection Impact Assessment:

Generali claims that it was not necessary to carry out a DPIA for the SMC application because, according to its risk analysis, the processing did not involve a high risk to the rights and freedoms of individuals. However, as indicated in the initiation agreement, there are several factors that justify the need for a DPIA, including the considerable volume of personal data processed and the combination of financial data (in this case, the IBAN) with identifying and contact data, as this multiplies the risk of identity theft and serious financial harm.

Article 35 of the GDPR requires a DPIA for processing that, due to its nature, scope, context, or purposes, may involve a high risk. The management of data from a large number of clients certainly falls into this category, as the impact of a potential data breach would be considerably greater.

Generali cannot dismiss the need for a DPIA based solely on its own analysis, especially when dealing with large-scale and sensitive data.

Furthermore, Generali argues that it does not process special category data in the SMC, based on its own interpretation of the data handled. However, the fact that Generali manages health insurance implies the processing of medical data at some point, even if this specific data was not directly involved in the SMC. The risk assessment must consider all possible processing scenarios and the data that may be processed. The lack of a DPIA to assess these risks demonstrates a lack of foresight and diligence on the part of Generali.

In this regard, we must emphasize that the case law of the CJEU has recognized the broad concept of special categories of personal data.

In this sense, the CJEU ruling of October 4, 2024, in case C 21/23, specifically regarding health data, determines that when the processing of personal data may indirectly reveal sensitive information about

a person, such data falls under the regime provided for in Article 9 of the GDPR:

“82 In particular, such provisions should not be interpreted as meaning that the processing of personal data that may indirectly reveal sensitive information about an individual is outside the enhanced protection regime established by the aforementioned provisions, as excluding it would undermine the useful effect of that regime and the protection of the freedoms and fundamental rights of individuals that it aims to guarantee (judgment of August 1, 2022, Vyriausioji tarnybinės etikos komisija, C 184/20, EU:C:2022:601, paragraph 127).”

Moreover, the aforementioned CJEU ruling indicates that special categories of personal data are subject to the prohibition of Article 9 of the GDPR regardless of whether the information is accurate or not and whether the processing aims to obtain personal data belonging to that category:

“87 This principle prohibition is independent of whether the information revealed by the processing in question is or is not accurate and whether the processing aims to obtain personal data that belong to that category.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

27/53

no exact and that said pharmacist acts with the aim of obtaining information included in any of the special categories contemplated in Article 8, paragraph 1, of Directive 95/46 and Article 9, paragraph 1, of the GDPR. Indeed, considering the significant risks to the fundamental freedoms and rights of the data subjects generated by any processing of personal data included in such categories, these provisions aim to prohibit such processing, regardless of the purpose expressed and the accuracy of the information in question [see, in this regard, the judgment of July 4, 2023, Meta Platforms and others. (General terms of service of a social network), C 252/21, EU:C:2023:537, paragraphs 69 and 70].

Generali also claims that Article 35.3 of the GDPR and the list of processing operations that require a DPIA do not apply to its specific processing. However, this interpretation is restrictive and does not take into account the complete nature of the data processing by Generali, and this notwithstanding the fact that the list is indicative and not exhaustive and aims to guide data controllers in identifying those processing operations that require a DPIA.

In conclusion, Generali has not adequately justified the lack of a DPIA. The management of a large volume of personal data and the processing of special categories of personal data, as in this case, require a thorough assessment of the risks, which must be documented through a DPIA. The absence of this assessment reflects a lack of compliance with Article 35 of the GDPR.

Insufficiency of security measures (Article 32 of the GDPR):

Generali argues that the AEPD has incorrectly interpreted the nature of the obligations imposed by this article and that it has based its decision on an erroneous assessment of the facts.

Generali asserts that the obligation to adopt security measures is an obligation of means, not of results, according to the jurisprudence of the Supreme Court. This means that the company must demonstrate that it has taken all reasonably necessary and appropriate measures to protect personal data, but it cannot be held automatically liable for a security breach if those measures proved insufficient to prevent it.

It should be noted again that the infringement of Article 32 of the GDPR is not due to the personal data breach itself, but rather that the personal data breach simply revealed the deficiencies and shortcomings in the security measures that Generali should have implemented beforehand. These deficiencies did not manifest directly due to the breach, but rather after the verification and analysis that took place following the occurrence of the breach. Subsequent verification revealed that the existing security measures were insufficient to prevent unauthorized access, demonstrating a failure to comply with the obligation to adopt adequate and proportionate security measures to the risk. And this is irrespective of the occurrence of the personal data breach.

It should be noted that the measure referred to as an example by Generali corresponds to a measure typical of data protection by design.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
28/53

Generali has mentioned the implementation of reactive security measures after the incident as:

o
(...)

The aforementioned measures demonstrate that the measures previously implemented were clearly insufficient to guarantee an adequate level of security relative to the risk, independently of the breach that occurred.

Thus, for example, it had not been foreseen (...).

In conclusion, Generali has not effectively complied with the obligations of Article 32 of the GDPR. The post-breach analysis, as well as the reactive measures adopted subsequently, evidence an insufficiency in the preventive security measures that should have been determined, implemented, and applied, something that Generali has not demonstrated it did satisfactorily before the incident.

Violation of the principle of confidentiality (Article 5.1.f of the GDPR):

Generali argues that no infringement has occurred, as the principle of confidentiality would have been compromised solely due to the personal data breach, and not due to an intrinsic lack of adequate measures.

However, this position is not sustainable.

Thus, for example, the (...).

Furthermore, while they had measures in place before the personal data breach for the (...).

This security measure does not serve to detect other types of common attacks. It was a clearly insufficient security measure.

In this regard, it should be noted that it is very common today for distributed denial-of-service attacks to occur, meaning that they are launched from many different IP addresses, so commonly used measures should have been anticipated to prevent, detect, and respond to this other type of attack.

Such measures were not implemented, resulting in the personal data breach occurring because a distributed attack was not detected.

Generali also claims that the attack (...) was a factor beyond its control. However, the security of information systems must consider the possibility of external brute-force attacks, such as the one that occurred – (...); hence the preventive measures such as multifactor authentication, which should have been implemented before the incident; it is not understood (...), resulting in a security measure that was not properly implemented and that has been established after the personal data breach. Thus, as has been evidenced:

-

(...).

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
29/53

The personal data breach allowed unauthorized access to a considerable number of personal data, including identifying data, contact information, financial information, and residential addresses, resulting in a loss of confidentiality.

Generali also argues that the need to communicate the facts to such a high number of affected individuals reflects the severity of the incident. This argument, far from exonerating Generali, demonstrates the impact that the personal data breach can have on its relationship with the principle of confidentiality. The large scale of the notification is a clear indication of the magnitude of the violation of the principle of confidentiality in that the personal data breach entails a high risk to the rights and freedoms of individuals.

In summary, the violation of the principle of confidentiality has been clearly established through the exposure of personal data to unauthorized third parties. The exposure of personal data on the observed scale is a clear indication that the obligation to ensure the confidentiality of personal data was not fulfilled, as required by Article 5.1.f of the GDPR.

Fourth Allegation: Regarding the Violation of the Principle of Proportionality

Generali's fourth allegation regarding the violation of the principle of proportionality is unfounded when analyzing the facts and the applicable legal provisions. The AEPD has carefully evaluated the concurrent circumstances and has applied the principle of proportionality when determining the sanctions, in accordance with Article 83 of the GDPR. Generali argues that the AEPD did not consider certain mitigating factors and applied aggravating factors without justification, which can be refuted in the terms that follow.

Thus, Generali argues that the reactive measures taken after the incident should be considered mitigating factors. However, the fact that reactive measures have been taken does not exempt the company from initial responsibility for failing to implement appropriate security measures at the level of risk, as due diligence must be exercised when it comes to a company that manages a large volume of personal data, including special categories of personal data. Corrective actions, while necessary, do not compensate for the lack of adequate proactive measures to protect personal data in companies of this nature, whose potential consequences can be exacerbated and amplified considering the large-scale processing they conduct.

Generali also claims that it has not been subject to previous sanctions and that this should be considered a mitigating factor. However, the severity of the current infringement and the potential impact on a large number of individuals in this case justify an appropriate sanction regardless of the entity's prior sanctioning history. In this sense, the National Court in its ruling 1437/2020 of May 5, 2021, stated that "Article 83.2 of the GDPR establishes that, among other factors, the circumstance 'e) any previous infringement committed by the data controller or the processor' must be taken into account for the imposition of the administrative fine." This is an aggravating circumstance; the fact that the prerequisite for its application does not occur means that it cannot be taken into consideration, but it does not imply or allow, as the plaintiff intends, its application as a mitigating factor."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

30/53

Regarding Generali's assertion that the AEPD was made aware of the incident through the company's voluntary notification, it should be noted that such communication is an obligation provided for by the GDPR itself and not a voluntary act that deserves consideration as a mitigating factor.

As for adherence to codes of conduct, Generali mentions its participation in the development of best practice guidelines. Although these efforts are positive, they do not exempt the entity from the responsibility of complying with all provisions of the GDPR effectively and continuously.

The AEPD has correctly applied the aggravating circumstances. The large scale of data processing, the nature of the data processed, and the special negligence in adopting adequate protective measures justify the application of aggravating factors. These aggravating factors are not based on unfounded subjective assessments but on a detailed evaluation of the facts, risks, and the impact of the infringement presented in this resolution.

In conclusion, the AEPD has followed an appropriate and justified methodology to evaluate both the mitigating and aggravating circumstances in this case, providing justification for it, and has applied the principle of proportionality in accordance with current regulations. The proposed sanctions reflect the seriousness of the infringements.

IV Unfulfilled obligation of Article 5.1 f)

According to paragraph 1.f) of Article 5 of the GDPR, data must be:

“processed in a manner that ensures appropriate security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage, by applying appropriate technical or organizational measures (‘integrity and confidentiality’).”

Similarly, Recital 39 of the GDPR states: "Personal data must be processed in a manner that ensures appropriate security and confidentiality of personal data, including to prevent unauthorized access or use of such data and of the equipment used for processing."

The aforementioned principle of confidentiality aims to ensure that personal data is accessible only to those authorized to use it and for the specific purposes for which it was collected. In these terms, any exposure or unauthorized processing of personal data would constitute a violation of the aforementioned principle. This occurs when personal data is accessible to unauthorized individuals or entities, or when it is used for purposes other than those for which it was originally collected or consented to by its owner.

In the present case, from the investigative actions carried out by this authority, a violation of the principle of confidentiality is evident due to the failure to ensure adequate security of personal data, including protection against unauthorized or unlawful processing, through the application of technical measures and organizational measures.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

31/53

appropriate organizational measures, which has been materialized with the unauthorized exposure of personal data of a considerably high number of individuals. Among the exposed data were personal identification data, contact information, financial information, and residential addresses. The number of affected and potentially affected individuals results from the formal communications of the incident made by the defendant party to those affected, which were also provided during the aforementioned proceedings. Thus, it claims to have communicated the incident to 24,352 directly affected individuals who were included in the sample file obtained from the attackers through the cybersecurity company Lazarus. In addition, communication was made to 1,092,543 policyholders not included in the sample file and 399,153 former insured individuals of individual policies, whose contact data were not available. Finally, a public communication was included for 166,621 former insured individuals of collective policies, raising the total number of potentially affected individuals to over 1.6 million. The need to communicate the facts to such a high number of individuals (more than one and a half million), besides reflecting the relevance of the personal data breach, also demonstrates the recognition of its severity by the defendant party. The detection of the attack and the subsequent investigation that revealed the unauthorized access to personal data confirms this assertion. It also highlights the number of personal data compromised for each affected individual. The fact that detailed data such as ID numbers, contact information, and personal addresses, among others, were exposed, manifests the magnitude of the breach. It should be noted that, in a considerable number of cases, financial data such as IBANs were exposed, which, along with the combination of identifying and locational data, exposes the affected individuals to a significant risk of fraud, such as identity theft and financial fraud, criminal acts that, unfortunately, are common today. The circumstance that someone claimed to possess certain data of former clients (800,000, according to the defendant party) in a Telegram forum, and that the cybersecurity company Lazarus provided a sample to the defendant party, cannot be overlooked. Given that Telegram is a publicly accessible messaging platform, it presents a concerning scenario, as making this information available in an open and easily accessible environment increases the risk of such data being misused. Finally, from the investigative proceedings, it follows that the violation of the principle of confidentiality, in this case, is not limited solely to the cyberattack that occurred. Likewise, the circumstance that insurance mediators, both agents and brokers, at the time of the incident could view and access the data of former clients, despite having terminated their commercial relationship with the defendant party, represents a further manifestation of this violation. Furthermore, we refer to the breach of this obligation to what has been addressed in the third allegation regarding the lack of technical and organizational measures concerning the personal data breach.

C/ Jorge Juan, 6

www.aepd.es

For the reasons stated, there is a violation of Article 5.1(f) of the GDPR for failing to ensure adequate security of personal data, including protection against unauthorized or unlawful processing, through the application of appropriate technical and organizational measures.

V Classification and Qualification of the Violation of Article 5.1(f) of the GDPR

If confirmed, the aforementioned violation of Article 5.1(f) of the GDPR could constitute the commission of the violations classified in Article 83.5 of the GDPR, which under the heading "General Conditions for the Imposition of Administrative Fines" states:

"Violations of the following provisions shall be subject to administrative fines of up to 20,000,000 EUR or, in the case of an enterprise, an amount equivalent to 4% of the total global annual turnover of the preceding financial year, opting for the higher amount:

a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9; (...)"

In this regard, the LOPDGDD, in its Article 71 "Violations" establishes that "Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute violations."

For the purposes of the statute of limitations, Article 72 "Very Serious Violations" of the LOPDGDD indicates:

"1. In accordance with what is established in Article 83.5 of Regulation (EU) 2016/679, the following violations are considered very serious and shall be subject to a three-year statute of limitations, which involve a substantial breach of the articles mentioned therein and, in particular, the following:

a) The processing of personal data violating the principles and guarantees established in Article 5 of Regulation (EU) 2016/679. (...)"

VI Sanction for Non-compliance with Article 5.1(f)

According to Article 83.2 of the GDPR, "Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure to those provided for in Article 58, paragraph 2, letters a) to h) and j). In deciding on the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account:

a) the nature, gravity, and duration of the violation, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of data subjects affected and the level of damage and harm suffered;

b) the intentionality or negligence in the violation;

c) any measures taken by the controller or processor to mitigate the damage and harm suffered by the data subjects;

d) the degree of responsibility of the controller or processor, taking into account the technical or organizational measures they have applied under Articles 25 and 32;

e) any previous violations committed by the controller or processor;

f) the degree of cooperation with the supervisory authority in order to remedy the violation and mitigate the possible adverse effects of the violation;

g) the categories of personal data affected by the violation;

h) the manner in which the supervisory authority became aware of the violation, in particular whether the controller or processor notified the violation and, if so, to what extent;

i) when the measures indicated in Article 58, paragraph 2, have been previously ordered against the controller or processor in relation to the same matter, compliance with those measures;

j) adherence to codes of conduct under Article 40 or to certification mechanisms approved under Article 42, and

k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the violation."

Similarly, Article 76 of the LOPDGDD establishes a series of criteria for grading the possible sanction, following the provisions of paragraph k) of the previous article:

“In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

- a) The ongoing nature of the violation.
- b) The connection of the infringer's activity with the processing of personal data.
- c) The benefits obtained as a result of the commission of the violation.
- d) The possibility that the conduct of the affected party may have induced the commission of the violation.
- e) The existence of a merger by absorption after the commission of the violation, which cannot be attributed to the absorbing entity.
- f) The impact on the rights of minors.
- g) Having a data protection officer when not mandatory.
- h) The voluntary submission by the controller or processor to alternative dispute resolution mechanisms, in cases where there are disputes between them and any data subject.”

Taking these provisions into account, in the present case it is considered appropriate to grade the sanction to be imposed in the following terms:

Aggravating factor provided for in paragraph a) of Article 83.2 of the GDPR:

- a) the nature, gravity, and duration of the violation, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of data subjects affected and the level of damage and harm suffered;

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
34/53

as the number of affected parties and the level of damages they have suffered;

In the present case, the severity of the infringement arises from several aspects: the considerable number of affected parties and their personal data, as well as the fact that several of these personal data will be for sale on an electronic messaging network. These circumstances, taken together, increase the potential risk of harm to the affected individuals, as the data to which they are entitled may fall into the hands of malicious actors intending to commit fraud, extortion, or other criminal activities.

Aggravating factor provided for in section b) of Article 83.2 of the GDPR:

- b) the intentionality or negligence in the infringement;

In this case, serious negligence can be appreciated on the part of the respondent. In this regard, the Supreme Court has understood that there is recklessness whenever a legal duty of care is disregarded, that is, when the infringer does not behave with the required diligence. In assessing the degree of diligence, the professionalism or lack thereof of the subject must be especially weighed, and there is no doubt that, in the case now examined, given that the activity of the appellant involves constant and abundant management of personal data, a greater rigor and exquisite care is required in order to comply with the provisions (Judgment of the National Court of October 17, 2007 (rec. 63/2006)).

Aggravating factor provided for in section b) of Article 76 of the LOPDGDD: The link of the infringer's activity with the processing of personal data.

The concurrence of the aforementioned aggravating factor arises from the nature of the activity of the respondent. It is evident that, as an insurer, it periodically carries out operations that involve the management and processing of large volumes of personal data. This special link with the personal data it manages implies a greater responsibility to prevent such data from being exposed or improperly processed by authorized persons. On the contrary, the violation of the principle of confidentiality by entities whose activity presents such a link aggravates the infringing conduct, which consequently motivates the concurrence of the present aggravating factor.

No mitigating circumstances are appreciated.

Taking into account the general conditions for the imposition of administrative fines established by the aforementioned Article 83.2 of the GDPR, considering the circumstances of the present case, the

initiation agreement proposed a fine of 1,000,000 € (ONE MILLION EUROS) as a sanction.

VII Unfulfilled obligation of Article 32

Article 32 "Security of processing" of the GDPR establishes:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

35/53

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the varying probability and severity of risks to the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
- d) a process for the regular verification, evaluation, and assessment of the effectiveness of the technical and organizational measures to ensure the security of processing.

2. In assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data may only process such data on instructions from the controller, unless required to do so by Union or Member State law."

It is necessary to point out that the aforementioned provision does not establish a list of specific security measures according to the data being processed, but rather establishes the obligation for the controller and the processor to apply technical and organizational measures that are appropriate to the risk posed by such processing, taking into account the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing, and the probability and severity of risks to the rights and freedoms of the data subjects.

Furthermore, the security measures must be adequate and proportionate to the identified risk, determining those appropriate technical and organizational measures considering pseudonymization and encryption, the ability to ensure confidentiality, integrity, availability, and resilience, the ability to restore availability and access to data after an incident, and the process of verification (which is not an audit), evaluation, and assessment of the effectiveness of the measures.

In any case, when assessing the appropriateness of the level of security relative to the risk, particular consideration must be given to the risks presented by the processing of data, as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the communication or access.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

36/53

unauthorized access to such data that could cause physical, material, or immaterial damages.

For its part, Recital 83 of the GDPR states that "(83) In order to maintain security and prevent processing from infringing the provisions of this Regulation, the controller or the processor must

assess the inherent risks of processing and implement measures to mitigate them, such as encryption. These measures must ensure an adequate level of security, including confidentiality, taking into account the state of the art and the cost of their implementation in relation to the risks and the nature of the personal data that needs to be protected. When assessing the risk in relation to data security, the risks arising from the processing of personal data must be taken into account, such as the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data, which may in particular cause physical, material, or immaterial damages.”

In this case, the investigations carried out by the present supervisory authority have revealed that, regardless of the breach that occurred, while the respondent had implemented certain data security measures, they were not sufficient to meet the requirements set forth in the aforementioned Article 32. As indicated, this provision establishes the need to implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk. The inadequacy or insufficiency in this case arises from several statements made by the respondent during the aforementioned investigative proceedings.

Similarly, the entity has confirmed shortcomings in the technical measures deployed (...). This deficiency prevents the respondent from conducting an analysis of the activity taking place in the aforementioned application. This poses a greater difficulty in identifying anomalous usage patterns, unauthorized access, or any other form of abuse or misuse of personal data, including that which may be carried out by its own staff.

On the other hand, it is worth mentioning the numerous reactive measures adopted by the respondent after the incident, which were communicated to the present authority during the investigative proceedings. The adoption of such reactive measures highlights the absence of certain basic security measures considering the risk arising from its activity.

(...).

Thus, for example, (...), an insufficient security measure independent of the personal data breach. While reactive measures are essential to address vulnerabilities and prevent future breaches, the need for their adoption underscores an inadequacy or insufficiency of the measures taken, which implicitly implies an acknowledgment by the respondent of the existence of deficiencies in its data security approach.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
37/53

Lastly, the considerable number of users managed by the respondent in exercising its activity cannot be overlooked, a circumstance that intrinsically entails a high risk in terms of personal data protection and, consequently, the implementation of security measures appropriate to the level of risk. It must be taken into account that, in this context, the risks associated with processing are amplified due to the amount of data managed and the potential severity of any breach. This implies that any failure in security measures would not only affect a greater number of individuals but could also have more serious consequences, both in terms of impact on the potential affected parties and liability for the respondent.

Furthermore, we refer to the response provided in the third allegation regarding the lack of appropriate technical and organizational security measures relative to the level of risk concerning the breach of this obligation.

In light of the above, from the mentioned investigative actions and assertions of the entity itself, regardless of the incident that occurred and its consequences, it is evident that the security measures adopted by the respondent are inadequate to the risk, considering the amount of data it managed.

VIII Classification and Qualification of the Violation of Article 32 of the GDPR

If confirmed, the aforementioned violation of Article 32 of the GDPR could constitute the commission of the violations classified in Article 83.4 of the GDPR, which under the heading "General Conditions for the Imposition of Administrative Fines" states:

"Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 2% of the total global annual turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)" In this regard, the LOPDGDD, in its Article 71 "Violations," establishes that "Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute violations."

For the purposes of the statute of limitations, Article 73 "Violations Considered Serious" of the LOPDGDD indicates: "In accordance with what is established in Article 83.4 of Regulation (EU) 2016/679, violations that constitute a substantial breach of the articles mentioned therein are considered serious and shall be subject to a two-year statute of limitations, particularly the following: (...) f) The failure to adopt those technical and organizational measures that are appropriate to ensure a level of security adequate to the risk of processing, as required by Article 32.1 of Regulation (EU) 2016/679.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
38/53

IX Sanction for the infringement of Article 32 of the GDPR

In the terms indicated by the aforementioned Article 83.4 of the GDPR, the infringement of Article 32 shall be sanctioned "with administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 2% of the total global annual turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43;"

Taking into account the already mentioned Article 82.2 of the GDPR, in this case, it is considered appropriate to scale the sanction to be imposed in the following terms:

a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of affected data subjects and the level of damage and harm they have suffered;

In this case, the severity of the infringement arises from the potential risk that exists in the protection of personal data due to the lack of adoption of basic security measures by the party being claimed against, considering the considerable volume of data it manages and their nature. These circumstances mean that the effects of any personal data breach that may occur are amplified with considerable harm to the possible affected parties resulting from it.

b) the intent or negligence in the infringement;

Taking into account the previously indicated doctrine, this aggravating factor arises from a lack of due diligence in adopting appropriate security measures relative to the risk by the party being claimed against. It should be noted that in this case, considering the nature and volume of data managed by the party being claimed against, a special legal duty of care is required, which, in this case, has not been fulfilled, leading to gross negligence in its actions. (Judgment of the National Court of October 17, 200, case number 63/2006).

Taking into account the general conditions for the imposition of administrative fines established by the aforementioned Article 83.2 of the GDPR, considering the circumstances of this case, the initiation agreement proposed a possible sanction of a fine in the amount of 1,000,000 € (ONE MILLION EUROS).

X Unfulfilled obligation of Article 25 of the GDPR

For its part, Article 25 of the GDPR, regarding Data Protection by Design and by Default, establishes the following:

"1. Taking into account the state of the art, the cost of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity that the processing entails for the rights and freedoms of...

Individuals, the data controller shall apply, both at the time of determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures, such as pseudonymization, designed to effectively apply the principles of data protection, such as data minimization, and integrate the necessary safeguards in the processing, in order to comply with the requirements of this Regulation and protect the rights of the data subjects.

2. The data controller shall apply appropriate technical and organizational measures to ensure that, by default, only personal data that are necessary for each specific purpose of the processing are processed. This obligation shall apply to the amount of personal data collected, the extent of their processing, their retention period, and their accessibility. Such measures shall ensure in particular that, by default, personal data are not accessible, without the intervention of the individual, to an indeterminate number of natural persons.

3. An approved certification mechanism in accordance with Article 42 may be used as an element to demonstrate compliance with the obligations set out in paragraphs 1 and 2 of this Article.”

In line with these provisions, Recital 78 of the GDPR states:

“The protection of the rights and freedoms of natural persons with regard to the processing of personal data requires the adoption of appropriate technical and organizational measures to ensure compliance with the requirements of this Regulation.

In order to demonstrate compliance with this Regulation, the data controller must adopt internal policies and implement measures that comply in particular with the principles of data protection by design and by default. Such measures could consist, among others, of minimizing the processing of personal data, pseudonymizing personal data as soon as possible, providing transparency regarding the functions and processing of personal data, allowing data subjects to monitor the processing of data, and enabling the data controller to create and improve security elements.

When developing, designing, selecting, and using applications, services, and products that are based on the processing of personal data or that process personal data to fulfill their function, producers of products, services, and applications should be encouraged to take into account the right to data protection when developing and designing these products, services, and applications, and to ensure, with due regard to the state of the art, that data controllers and processors are in a position to fulfill their obligations regarding data protection.

The principles of data protection by design and by default must also be taken into account in the context of public contracts.”

As can be seen, Article 25 of the GDPR considers data protection not as an afterthought, but as an integral and priority element in the design of systems, processes, and products. This implies that security measures must be considered from the earliest stages of development of any system or process that processes any type of personal data, which leads to placing data protection at the central aspect of the design of such systems and processes.

The principle of data protection by design reflects a fundamental shift from a reactive stance to a proactive one, which is a manifestation of the risk-based approach promoted by the GDPR, emphasizing anticipation and prevention in the management of personal data. Under this approach, the responsibility to protect personal data begins at the earliest stages of planning any data processing activity. This means that the data controller must incorporate measures that ensure protection at the very moment when the processing of personal data is being designed and planned. This proactive approach involves identifying and addressing potential risks from the outset, integrating the necessary

safeguards directly into the data processing processes and systems.

In this regard, when applying data protection by design, all elements that constitute data processing must be considered, including the nature of the data, the purposes of processing, as well as the possible consequences for the rights and freedoms of the affected individuals. The aim is to ensure that data protection principles, such as minimization, purpose limitation, and data security, are effectively and consistently implemented throughout the entire data processing lifecycle.

This is expressed in the Guidelines 4/2019 of the European Data Protection Board (EDPB) regarding Article 25 Data Protection by Design and by Default, adopted on October 20, 2020. In the aforementioned Guidelines, it is stated that:

“The ‘moment of determining the means of processing’ refers to the period of time when the controller is deciding how the processing will be carried out and how it will occur, as well as the mechanisms that will be used to carry out such processing. In the process of making such decisions, the data controller must assess the appropriate measures and safeguards to effectively apply the principles and rights of the data subjects in the processing, and take into account elements such as risks, the state of the art, and the cost of implementation, as well as the nature, scope, context, and purposes. This includes the moment of acquiring and implementing software and hardware and data processing services.

Considering data protection by design from the outset is crucial for the correct application of the principles and for the protection of the rights of the data subjects. Furthermore, from a cost-effectiveness perspective, it is also in the interest of data controllers to take data protection by design into consideration as early as possible, as it may later become difficult and costly to introduce changes to already formulated plans and designed processing operations.”

To this end, when designing the processing, the principles set out in Article 5 of the GDPR must be referred to, which will serve to assess the effective compliance with the GDPR. Thus, the aforementioned Guidelines 4/2019 of the EDPB state that

“61. To make data protection by design effective, data controllers must apply the principles of transparency, lawfulness, fairness, purpose limitation, data minimization, accuracy, storage limitation, integrity, and confidentiality, and...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

41/53

proactive responsibility. These principles are outlined in Article 5 and Recital 39 of the GDPR.”

The Privacy by Design Guide from the AEPD states that “Privacy by Design (hereinafter, PbD) involves using a risk management and proactive responsibility approach to establish strategies that incorporate privacy protection throughout the entire lifecycle of the object (whether it is a system, hardware or software product, service, or process). The lifecycle of the object refers to all the stages it goes through, from its conception to its withdrawal, including the phases of development, production, operation, maintenance, and withdrawal.”

The Guide stipulates that “Privacy must be an integral and inseparable part of systems, applications, products, and services, as well as of the business practices and processes of the organization. It is not an additional layer or module that is added to something pre-existing, but must be integrated into the set of non-functional requirements from the very moment it is conceived and designed (...) Privacy is born in the design, before the system is operational, and must be guaranteed throughout the entire data lifecycle.”

Regarding the case at hand, during the course of the investigative proceedings, it has become evident that it was not taken into account that the data of former clients must be retained for purposes other than those existing during the time the policy is in force. As the responding party itself states, the new purpose is limited to compliance with tax and insurance regulatory obligations, among others.

According to their statements, these circumstances had not been considered because they did not have the data physically separated, in differentiated equipment, nor did they have a logical separation between them, as both types of clients were listed in the same database, and even in the same table (PERSONAS). This resulted in, regardless of the breach suffered, both insurance agents and brokers

having access to the personal data of former clients, even though these clients no longer had an active policy. In other words, access to personal data was allowed for certain individuals who were no longer authorized, as the holders of such data were no longer considered clients and, consequently, the purpose of such processing had already concluded, being limited from that moment on to compliance with certain mandatory regulations.

This fact, consisting of the possibility of accessing data of former clients by individuals who were no longer authorized, indicates that not all possible implications regarding data protection were taken into account at the time of creating the application intended for accessing and managing such data. In this regard, it is worth noting that, unlike what occurred with the incident that took place (...), in the present case, the anomaly was not due to an unforeseen cause, but existed from the outset, that is, from the moment of the design and implementation of the application. This is not undermined by the fact that, as a consequence of the incident, awareness of this circumstance was gained and the responding party took reactive measures to resolve the problem.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
42/53

From the above, it follows that, at the time of designing the application or system in question, the principles established in Article 5 were not adequately taken into account; in particular, the principle of data minimization and the principle of limitation of personal data.

Thus, regarding the principle of data minimization, as indicated in the aforementioned Article 5 of the GDPR, its compliance requires that such data be “adequate, relevant, and limited to what is necessary in relation to the purposes for which they are processed (‘data minimization’). From the perspective of data protection by default and by design, this means that, from the earliest stages, it must be considered what data is truly necessary to achieve the intended objective and limit the collection and processing to such data. Similarly, effectively implementing this principle requires careful management of the lifecycle of personal data, ensuring that they are only processed for the period that is strictly necessary for the purposes for which they were collected.

The fact that at the time of creation and implementation of the system, the circumstance that (...) was not taken into account, indicates that the system was not designed with the principle of minimization in mind. The consequence is that processing occurs for a time longer than what was necessary for the fulfillment of the purpose for which it was initially authorized.

In the same way, regarding the principle of limitation of personal data, subsection b) of the aforementioned Article 5 of the GDPR requires that “data shall be collected for specified, explicit, and legitimate purposes, and shall not be further processed in a manner incompatible with those purposes, ...”. This principle entails that, when designing a system or process, the purpose of data collection must be clearly defined and limited. This means that, from the conceptualization phase, the purposes for which the data is collected must be clearly established. These purposes must be specific and explicit, and the system must be designed to support only the processing of data necessary to achieve those purposes.

Likewise, systems must be designed to control and restrict access to data based on the purpose of processing, which means that only individuals authorized for a specific purpose may have access to the data related to that purpose. To this end, systems must be capable of segregating and managing data according to their different purposes.

In the case at hand, if mechanisms were not incorporated when designing the application (...), the principle of limitation of personal data is not being taken into account. The system should have considered the different purposes existing throughout the processing cycle (for the execution of the contract, for compliance with regulations) and who is authorized to access such data according to the corresponding phase (intermediaries, staff, authorities...). Otherwise, the principle of limitation of personal data is violated, as it allows access to data by individuals who are no longer legitimized. On the other hand, the lack of a data protection approach from the outset and by default is also evident from the reactive measure taken by the respondent party after the incident to resolve the problem,

which consisted of (...).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

43/53

was deemed necessary, but its late implementation indicates a lack of data protection by default from the outset and by default. Data protection by default requires that measures be applied automatically, without requiring additional actions from the data controller or the user.

Lastly, it is also worth highlighting the nature of the activity of the responding party, which, as an insurance entity, manages a large volume of personal data, collecting and processing a significant amount of it, including sensitive information related to health, finances, and other personal data of its clients, including minors. The high volume of data, as well as its nature, increases both the complexity and the potential risk associated with its processing, which demands greater rigor in the necessity to adopt a data protection approach from the design stage and by default. It should be noted that, in mass data processing as occurs in the present case, any failure in the protective measures can have significant implications for a large number of individuals, making it crucial for the entities that manage them to implement systems and processes that incorporate security measures from the outset.

For the reasons stated, (...) despite having been resolved subsequently, it demonstrates non-compliance with Article 25 of the GDPR for not having adopted adequate measures that comply with the principles of data protection by design and by default.

XI Qualification of the infringement of Article 25 GDPR

The violation of Article 25 of the GDPR is classified in Article 83.4 of the same legal text, according to which:

“Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to 2% of the total global annual turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42 and 43;”

Regarding the statute of limitations, the infringement mentioned in the previous paragraph is considered serious and prescribes after two years, in accordance with Article 73 d) of the LOPDGDD, which establishes that:

“Based on what is established in Article 83.4 of Regulation (EU) 2016/679, the following are considered serious and shall prescribe after two years: violations that constitute a substantial breach of the articles mentioned therein and, in particular, the following:

d) The failure to adopt those technical and organizational measures that are appropriate to effectively apply the principles of data protection by design, as well as the failure to integrate the necessary guarantees in the processing, in the terms required by Article 25 of Regulation (EU) 2016/679.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

44/53

XII Sanction for the infringement of Article 25 of the GDPR

In the terms indicated by the aforementioned Article 83.4 of the GDPR, the infringement of Article 32 shall be sanctioned “with administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 2% of the total global annual turnover of the previous financial year, opting for the higher amount.”

Furthermore, taking into account Article 82.2 of the GDPR and Article 76 of the LOPDGDD, in the present case it is considered appropriate to scale the sanction to be imposed in the following terms:

-

Article 82.2 b) of the GDPR: “the intentionality or negligence in the infringement;

According to the previously indicated jurisprudential doctrine, this aggravating factor is also applicable in the present infringement, since, from the investigative actions, it is evident that there was a lack of

due diligence on the part of the respondent at the time of designing the application intended for the management by the intermediaries of their clients' data. The fact that the different purposes of the processing were not taken into account and that, as a consequence, the intermediaries could continue to access data of their former clients demonstrates serious negligence in its implementation, in the terms indicated by the aforementioned ruling of the National Court of October 17, 2007, case number 63/2006.

-

Article 76 b) of the LOPDGDD: "b) The link of the infringer's activity with the performance of personal data processing.;

The concurrence of the aforementioned aggravating factor is a consequence of the nature of the activity of the infringing entity, which, as an insurer, carries out activities that involve the management and processing of large volumes of personal data as a fundamental part of its operation. This special link with the personal data it manages implies a greater responsibility to ensure its protection from the design stage, and consequently, there is a greater expectation of compliance with the regulations in this area. Conversely, non-compliance with these requirements entails an amplification of the possible risks, which justifies the concurrence of the aforementioned aggravating factor.

Taking into account the general conditions for the imposition of administrative fines established by the aforementioned Article 83.2 of the GDPR, considering the circumstances of the present case, the agreement proposed a sanction of a fine in the amount of 2,000,000 € (TWO MILLION EUROS).

XIII Sanction for the infringement of Article 35 of the GDPR

Article 35, in relation to the Data Protection Impact Assessment, establishes the following:

"1. When it is likely that a type of processing, particularly if it uses new technologies, by its nature, scope, context, or purposes, entails a high risk for...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

45/53

the rights and freedoms of natural persons, the data controller shall carry out, prior to processing, an assessment of the impact of the processing operations on the protection of personal data. A single assessment may address a series of similar processing operations that involve similar high risks.

2. The data controller shall seek the advice of the data protection officer, if appointed, when carrying out the data protection impact assessment.

3. The data protection impact assessment referred to in paragraph 1 shall be required, in particular, in the case of:

a) systematic and comprehensive evaluation of personal aspects of natural persons based on automated processing, including profiling, and on which decisions are based that produce legal effects for the natural persons or similarly significantly affect them;

b) large-scale processing of special categories of data referred to in Article 9, paragraph 1, or of personal data relating to criminal convictions and offenses referred to in Article 10, or

c) systematic large-scale monitoring of a publicly accessible area.

4. The supervisory authority shall establish and publish a list of the types of processing operations that require a data protection impact assessment in accordance with paragraph 1.

The supervisory authority shall communicate these lists to the Committee referred to in Article 68.

5. The supervisory authority may also establish and publish a list of the types of processing that do not require data protection impact assessments. The supervisory authority shall communicate these lists to the Committee.

6. Before adopting the lists referred to in paragraphs 4 and 5, the competent supervisory authority shall apply the consistency mechanism provided for in Article 63 if those lists include processing activities related to the offering of goods or services to data subjects or to the monitoring of their behavior in several Member States, or processing activities that may substantially affect the free movement of personal data within the Union.

7. The assessment shall include at least:

- a) a systematic description of the envisaged processing operations and the purposes of the processing, including, where applicable, the legitimate interest pursued by the data controller;
- b) an evaluation of the necessity and proportionality of the processing operations in relation to their purpose;
- c) an assessment of the risks to the rights and freedoms of the data subjects referred to in paragraph 1, and
- d) the measures envisaged to address the risks, including safeguards, security measures, and mechanisms that ensure the protection of personal data, and to demonstrate compliance with this Regulation, taking into account

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
46/53

it accounts for the rights and legitimate interests of the interested parties and other affected persons.

8. Compliance with the approved codes of conduct referred to in Article 40 by the respective controllers or processors shall be duly taken into account when assessing the implications of the processing operations carried out by such controllers or processors, particularly for the purposes of the impact assessment related to data protection.

9. Where appropriate, the controller shall seek the opinion of the interested parties or their representatives regarding the intended processing, without prejudice to the protection of public or commercial interests or the security of the processing operations.

10. When the processing in accordance with Article 6, paragraph 1, letters c) or e), has its legal basis in Union law or in the law of the Member State applicable to the controller, such law regulates the specific processing operation or set of operations in question, and an impact assessment related to data protection has already been carried out as part of a general impact assessment in the context of the adoption of such legal basis, paragraphs 1 to 7 shall not apply unless Member States consider it necessary to carry out such assessment prior to the processing activities.

11. If necessary, the controller shall examine whether the processing is in compliance with the impact assessment related to data protection, at least when there is a change in the risk posed by the processing operations.

The need to implement a data protection impact assessment (DPIA) is a consequence of the principle of proactive responsibility provided for in the GDPR itself, and it is a fundamental tool to ensure that entities that present certain characteristics in their processing manage and process personal data responsibly, securely, and in accordance with the regulations in this area, thereby protecting the rights of their holders and strengthening trust in their operations.

The purpose of the DPIA, as established in the aforementioned Article 35 of the GDPR, is multiple and focuses on ensuring the protection of personal data of natural persons. Among these purposes, we can highlight:

- Identifying and assessing potential risks to the rights and freedoms of individuals that could arise as a result of the processing of personal data. This is especially important when new technologies are used or large-scale data processing is carried out.
- Helping organizations comply with the GDPR, as it ensures that regulatory requirements related to data protection are respected from the design stage and by default.
- Implementing measures to mitigate risks. Based on the identified risks, the DPIA guides entities in the implementation of the...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
47/53

appropriate measures to mitigate those risks. This may include adjustments in the way personal data is collected, stored, processed, or shared.

-
Prevent potential harm and/or data breaches, as proactive identification and risk mitigation through the DPIA helps prevent data breaches and other harms that could result from the improper processing of personal data, which may have legal consequences.

In this case, regarding this requirement and as stated by the responding party during the course of the investigation proceedings, it is evident that there exists only a document where a general analysis or description of the processing was carried out with the purpose of determining the need to conduct a Data Protection Impact Assessment (DPIA), concluding that the processing has a low impact level and, therefore, it was not necessary to carry out this DPIA. However, considering the characteristics of the nature and functions of the responding party, this diagnosis proved to be incorrect based on the reasons that will be outlined below.

First, it should be highlighted the considerable volume of clients managed by the responding party, which consequently involves the processing of personal data of these individuals on a large scale. In this sense, the greater the volume of data being processed, the higher the potential risk of security breaches and data violations. This is due, among other reasons, to the attractive amount of information it represents for cybercriminals, as well as the increased complexity of securely processing data on a large scale. Similarly, as the volume of data increases, it becomes more complex to ensure the rights of data subjects, such as access to their data, rectification, deletion, or portability.

Based on these circumstances, the need for a prior preparation of a DPIA arises as a fundamental instrument to mitigate the risks associated with the large-scale processing of personal data, as occurs in insurance entities operating on a national and/or international level. In massive volumes of data processing, this assessment allows for the proactive identification and addressing of risks before they occur, developing possible mitigation measures, which is essential to protect the rights and freedoms of individuals in the context of large-scale data processing.

Secondly, it is also worth mentioning the number of personal data that, in entities of this nature, is collected from each client. When we talk about the amount of personal data processed by an insurer for each client or individual, we refer to a potentially extensive and detailed set of information. In this sense, insurers, due to the nature of their services, collect and process a wide variety of personal data, which may include: identifying data, contact information, financial and banking data, employment and education, behavioral and preference data, previous claims,

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

48/53

derived and analytical data, among others, including special category data to which reference will be made later.

It should be noted that a large amount of detailed data about individuals increases the risk of this data being misused, either internally by the organization or by third parties who may access it without authorization. Large databases of personal information, such as those managed by insurers, are highly attractive to cybercriminals, as they include financial and personal identity details that can be exploited for fraud, identity theft, or sale on the black market. Therefore, the vast amount of personal data processed by clients makes Data Protection Impact Assessments (EIPD) essential, not only to meet formal requirements but also to ensure the effective protection of individuals' rights and freedoms.

Finally, it is worth mentioning the processing of special categories of personal data provided for in Article 9 of the GDPR. These special categories include those that reveal ethnic or racial origin, political opinions, religious or philosophical beliefs, or trade union affiliation, as well as the processing of genetic data, biometric data aimed at uniquely identifying a natural person, data related to health, or data related to the sexual life or sexual orientations of a natural person.

The main characteristic of the processing of such special categories of data is the provision for greater protection compared to other data, allowing their processing only when one of the circumstances provided for in the aforementioned Article 9 of the GDPR occurs. Considering this additional protection, the conduct of an EIPD is even more justified. In fact, the third paragraph of Article 35 of the

GDPR includes among the cases in which an EIPD is required the “large-scale processing of special categories of data referred to in Article 9, paragraph 1.”

In the case of insurance entities, as occurs with the claimed party in the present case, the processing of these special categories of personal data mainly affects health data, as this type of data is usually collected for the acquisition of certain products. This type of data is collected, of course, for the conclusion of the health insurance policies offered by the insurance entity itself. However, this information is also collected on various occasions for other types of insurance, in order to determine premiums fairly and accurately, based on the level of risk assessed after obtaining such information. Regardless of whether it is expressly provided for in Article 35, the processing of health data by insurers presents significant risks that fully justify the conduct of an EIPD, as it is essential to ensure that specific risks associated with this data are adequately identified and mitigated. Given its sensitive nature, the processing of health data carries high risks for the fundamental rights and freedoms of individuals. This includes the risk of discrimination, stigmatization, and harm to personal reputation.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

49/53

In conclusion, in the case at hand and without prejudice to what results from the instruction of the present procedure, taking into account the volume of data processed, including those with special categories, the technological changes that have occurred in recent years, as well as the risks that third parties may unlawfully appropriate such data, leads to the conclusion that the respondent should have conducted a DPIA (Data Protection Impact Assessment). This instrument aims to better understand the existing risks and the impacts that may arise from the processing and to attempt to ensure the confidentiality, integrity, and availability of personal data, thereby minimizing the risk of data breaches and guaranteeing the protection of individuals' rights and freedoms. The failure to conduct such a DPIA, on the contrary, constitutes a breach of the aforementioned Article 35 of the GDPR.

XIV Qualification and Classification of the Breach of Article 35 of the GDPR

If confirmed, the aforementioned breach of Article 35 of the GDPR could constitute the commission of the infringements classified in Article 83.4 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" states: "Infringements of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to 2% of the total global annual turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)"

In this regard, the LOPDGDD (Organic Law on Data Protection and Guarantee of Digital Rights), in its Article 71 "Infringements," establishes that "Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements."

For the purposes of the statute of limitations, Article 73 "Infringements considered serious" of the LOPDGDD indicates: "Based on what is established in Article 83.4 of Regulation (EU) 2016/679, the following are considered serious and shall prescribe after two years: infringements that constitute a substantial violation of the articles mentioned therein and, in particular, the following:

(...) t) The processing of personal data without having carried out the assessment of the impact of the processing operations on the protection of personal data in cases where it is required."

XV Possible Sanction for the Breach of Article 35 of the GDPR

In the terms indicated by the aforementioned Article 83.4 of the GDPR, the breach of Article 35 shall be sanctioned "with administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to 2% of the total global annual turnover of the previous financial year, opting for the higher amount."

C/ Jorge Juan, 6

www.aepd.es

Likewise, taking into account Article 82.2 of the GDPR and Article 76 of the LOPDGDD, in this case, it is considered appropriate to adjust the sanction to be imposed in the following terms:

-
Article 82.2 b) of the GDPR: a) the nature, severity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of affected data subjects and the level of damage and harm they have suffered;
In this case, the severity of the infringement arises from both the volume of personal data and the nature of the data itself, given that among them are special categories. Such circumstances aggravate the infringing conduct of not having carried out the DPIA despite being obliged to do so, as the failure to comply with this obligation increases the risk that the data subjects may suffer in their rights and freedoms.

-
Article 82.2 b) of the GDPR: “the intent or negligence in the infringement;
According to the previously indicated jurisprudential doctrine, this aggravating factor is also applicable in the present infringement, since, from the investigative actions, it is evident that there was a lack of due diligence in not having carried out the DPIA despite the nature of the activity and the personal data processed indicating its necessity; all of this in the terms indicated by the aforementioned ruling of the National Court of October 17, 2007, case number: 63/2006).

-
Article 76 b) of the LOPDGDD: “b) The link of the infringer's activity with the processing of personal data.;

The concurrence of the aforementioned aggravating factor is also a consequence of the nature of the infringing entity's activity, which, as an insurer, carries out activities that involve the management and processing of large volumes of personal data as a fundamental part of its operation. This special link with the personal data it manages implies a greater responsibility to ensure its protection and, consequently, the failure to carry out the DPIA, taking into account these circumstances, aggravates the conduct, justifying the concurrence of the aforementioned aggravating factor.

Taking into account the general conditions for the imposition of administrative fines established by the aforementioned Article 83.2 of the GDPR, considering the circumstances of the present case, the initiation agreement proposed a sanction of a fine in the amount of €1,000,000 (ONE MILLION EUROS).

XVI Adoption of measures

In accordance with the provisions of the aforementioned Article 58.2 d) of the GDPR, each supervisory authority may “order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, when appropriate, in a specific manner and within a specified period...”. The imposition of this measure is compatible with the sanction consisting of an administrative fine, as provided for in Article 83.2 of the GDPR.

In this case, the responsible party is required to notify this Agency of the adoption of the following measures within three months from the notification of this resolution:

- The completion and passing of the impact assessment of the processing operations on the protection of personal data as provided in Article 35 of the GDPR, with the minimum content indicated in said article, as well as the result of such assessment.

It is warned that failure to comply with the possible order to adopt measures imposed by this body in the sanctioning resolution may be considered an administrative infringement in accordance with the provisions of the GDPR, classified as an infringement in its Articles 83.5 and 83.6, which may lead to

the initiation of further administrative sanctioning proceedings.

XVII Voluntary Payment

In accordance with the provisions of Article 85 of the LPACAP, the agreement to initiate offered the summoned party the acknowledgment of their responsibility within the period granted for the submission of allegations to this initiation agreement; this will entail a reduction of 20% of the sanction that may be imposed in this procedure. With the application of this reduction, the sanction would be set at 4,000,000 euros, concluding the procedure with the imposition of this sanction.

Likewise, in the aforementioned agreement and in accordance with the indicated provision, it was allowed, at any time prior to the resolution of this procedure, to carry out the voluntary payment of the proposed sanction, which will imply a reduction of 20% of its amount. With the application of this reduction, the sanction would be set at 4,000,000 euros, and its payment will imply the termination of the procedure, without prejudice to the imposition of the corresponding measures.

It was also indicated that the reduction for the voluntary payment of the sanction is cumulative with that corresponding to the acknowledgment of responsibility, in which case, if both reductions were to be applied, the amount of the sanction would be set at 3,000,000 euros.

After the submission of allegations, and before a resolution proposal was issued by this authority, the summoned party, on April 12, 2024, proceeded to make the voluntary payment without acknowledging their responsibility, availing themselves of the 20% reduction and waiving any action or appeal in the administrative route, also expressing their intention to challenge the aforementioned resolution before the contentious-administrative jurisdiction.

It should be noted that, in accordance with the provisions of the LPCAP, as well as the jurisprudence of the high court in this matter, the exercise of voluntary payment by the alleged responsible party does not exempt the administration from the obligation to resolve and notify all proceedings, regardless of their initiation form. Likewise, Article 88 of the aforementioned regulation establishes that the resolution that concludes the procedure will decide all issues raised by the interested parties and those arising from it.

Based on the aforementioned premises, and considering that the summoned party prior to the voluntary payment submitted the allegations they deemed appropriate against the initiation agreement, this authority has proceeded to respond to and refute each of them, conducting a detailed analysis and legally substantiating the attribution of the infringements confirmed in this act, thus avoiding any defenselessness and allowing for a greater understanding regarding the issues raised by the summoned party.

Therefore, in accordance with the applicable legislation and assessed the criteria for the graduation of the sanctions whose existence has been established, the Director of the Spanish Agency for Data Protection

RESOLVES:

FIRST:

TO DECLARE the commission of the following infringements and CONFIRM for the purposes provided in Article 64.2 b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations the sanctions indicated in the initiation agreement for the commission of the aforementioned infringements:

For the infringement of Article 5.1.f): 1,000,000 € (ONE MILLION EUROS)

For the infringement of Article 32: 1,000,000 € (ONE MILLION EUROS)

For the infringement of Article 25: 2,000,000 € (TWO MILLION EUROS)

For the infringement of Article 35: 1,000,000 € (ONE MILLION EUROS)

The sum of the aforementioned amounts yields a total of 5,000,000 € (FIVE MILLION EUROS).

After the summoned party proceeded with the prompt payment, although without acknowledgment of responsibility, a reduction of 20% of the total mentioned is applied, which results in a definitive amount of 4,000,000 € (FOUR MILLION EUROS).

SECOND:

TO DECLARE the termination of the procedure due to the prompt payment made by GENERALI

ESPAÑA, SOCIEDAD ANONIMA DE SEGUROS Y REASEGUROS, with NIF A28007268, in accordance with the provisions of Article 85 of the Common Administrative Procedure Law of Public Administrations.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

53/53

THIRD:

TO REQUIRE GENERALI ESPAÑA, SOCIEDAD ANONIMA DE SEGUROS Y REASEGUROS to notify this Agency within three months from the notification of this resolution, the adoption of the following measures:

- The completion and passing of the impact assessment of the processing operations on the protection of personal data as provided in Article 35 of the GDPR, with the minimum content indicated in that article, as well as the result of such assessment.

It is warned that failure to comply with the possible order to adopt measures imposed by this body in the sanctioning resolution may be considered an administrative infringement in accordance with the provisions of the GDPR, classified as an infringement in its Articles 83.5 and 83.6, which may lead to the initiation of further administrative sanctioning proceedings.

FOURTH:

In accordance with the provisions of Article 85 of the LPACAP, which conditions the reduction for voluntary payment on the withdrawal or renunciation of any action or appeal in the administrative route, the present authority accepts the express renunciation manifested by the summoned party, consequently precluding the filing of an optional appeal for reconsideration against this resolution, all without prejudice to the possibility of resorting to the contentious-administrative jurisdiction.

Consequently, taking into account the provisions of Article 90 of the LPACAP, since there is no appeal in the administrative route due to the express renunciation, this resolution will be fully executable from the notification thereof.

However, in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative route may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency

[<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency is not aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, it will consider the provisional suspension to be concluded.

938-16012024

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es